Computer Security and privacy
Prof. Thomas Bourgeat

Luigi Ieracitano

October 31, 2026

Contents

1 Introduction to Computer Security **4**

1.1 Why a course on computer security? . . . 4

1.2 What is computer security? . . . 4

1.2.1 Traditional properties: the CIA triad . . . 4

1.2.2 Not-so-traditional (but important) properties . . . 5

1.3 The security policy . . . 5

1.4 The adversary and the threat model . . . 6

1.4.1 Key vocabulary to talk about the adversary . . . 6

1.5 Securing a system: security mechanisms . . . 7

1.5.1 Composing multiple mechanisms . . . 7

1.5.2 Humans are part of the system . . . 7

1.6 How do we show systems are secure? . . . 8

1.7 Security engineering . . . 8

1.8 Summary . . . 9

2 Principles of Computer Security **9**

2.1 Motivation . . . 9

2.1.1 Motivating example: the Heartbleed bug . . . 10

2.2 The eight core principles . . . 10

2.2.1 1 – Economy of mechanism . . . 10

2.2.2 2 – Fail-safe defaults . . . 11

2.2.3 3 – Complete mediation . . . 11

2.2.4 4 – Open design . . . 12

2.2.5 5 – Separation of privilege . . . 13

2.2.6 6 – Least privilege . . . 13

2.2.7 7 – Least common mechanism . . . 14

2.2.8 8 – Psychological acceptability . . . 14

2.3 Two extra principles (from physical security) . . . 15

2.3.1 9 – Work factor . . . 15

2.3.2 10 – Compromise recording . . . 15

2.4 Applying the principles: a machine learning example . . . 16

2.5 Summary . . . 16

3 Access Control **17**

3.1 Introduction to access control . . . 17

3.1.1 What is access control? . . . 17

3.1.2 Why is access control so important? . . . 17

3.1.3 Where does access control fit? Authentication vs. authorization . . . 18
3.1.4 Implementing access control: the reference monitor . . . 18
3.1.5 Who decides the access policy? DAC vs. MAC . . . 19
3.2 Discretionary Access Control (DAC) . . . 19
3.2.1 Historical motivation: Lampson's protection . . . 19
3.2.2 The Access Control Matrix . . . 19
3.2.3 Access Control Lists (ACLs) . . . 20
3.2.4 Role Based Access Control (RBAC) . . . 21
3.2.5 Group Based Access Control . . . 21
3.2.6 Capabilities . . . 22
3.3 Ambient authority and the confused deputy . . . 23
3.3.1 Ambient authority . . . 23
3.3.2 The confused deputy problem . . . 23
3.4 Summary of the DAC concepts . . . 24
3.5 DAC in practice: Linux (UNIX) and Windows . . . 24
3.5.1 UNIX: principals and groups . . . 24
3.5.2 Windows . . . 28
3.5.3 Comparison UNIX vs. Windows . . . 29
3.6 Summary . . . 29
3.7 From DAC to MAC . . . 30
3.7.1 Recall: who decides the policy? . . . 30
3.7.2 Security models . . . 30
3.8 Bell–La Padula (BLP): protecting confidentiality . . . 31
3.8.1 Subjects, objects and access rights . . . 31
3.8.2 Security levels of objects: classification . . . 31
3.8.3 The dominance relationship . . . 32
3.8.4 Security levels of subjects: clearance . . . 33
3.8.5 The simple security property (ss-property): No Read Up . . . 33
3.8.6 The star property (*-property): No Write Down . . . 34
3.8.7 The discretionary property (ds-property) . . . 35
3.8.8 The Basic Security Theorem . . . 35
3.8.9 Covert channels . . . 35
3.8.10 Declassification . . . 36
3.8.11 Limitations of BLP . . . 37
3.9 Integrity models . . . 37
3.9.1 Why integrity? . . . 37
3.9.2 The BIBA model . . . 37
3.9.3 BIBA variant 1: low-water-mark for subjects . . . 38
3.9.4 BIBA variant 2: low-water-mark for objects . . . 39
3.9.5 BIBA additional action: invoke . . . 40
3.9.6 Sanitization . . . 40
3.9.7 Principles to support integrity . . . 40
3.10 The Chinese Wall model . . . 41
3.10.1 Motivation . . . 41

3.10.2 Entities and basic concepts . . . 41
3.10.3 Access rule . . . 42
3.10.4 Indirect flows . . . 42
3.10.5 Multilateral security . . . 43
3.11 Summary . . . 43

4 Applied Cryptography **44**
4.1 Introduction . . . 44
4.1.1 Why does cryptography matter? . . . 44
4.1.2 The core problem: secure communication over an insecure channel . . . 44
4.1.3 Encryption and decryption . . . 45
4.1.4 The core requirements . . . 45
4.1.5 Bits of security . . . 46
4.2 Bad cryptography: classical ciphers . . . 46
4.2.1 Caesar's cipher . . . 46
4.2.2 The substitution cipher . . . 47
4.3 Adversaries in cryptography . . . 48
4.3.1 Passive eavesdropping (ciphertext-only) . . . 48
4.3.2 Active adversaries . . . 48
4.4 Perfect secrecy and the One-Time Pad . . . 51
4.4.1 Removing frequency analysis . . . 51
4.4.2 Why is the OTP perfectly secure? . . . 51
4.4.3 The key problem of the OTP . . . 52
4.4.4 Key reuse: the "two-time pad" . . . 52
4.4.5 The OTP does not provide integrity . . . 53
4.5 From the OTP to stream ciphers . . . 53
4.5.1 Symmetric cryptography . . . 53
4.5.2 Stream ciphers: the pseudo-OTP . . . 54
4.5.3 Interlude: building keystream generators . . . 56
4.5.4 Bit security and consequences: do not roll your own crypto . . . 57
4.6 Public-key cryptography . . . 57
4.6.1 Recap: the key distribution problem . . . 57
4.6.2 Diffie–Hellman key exchange . . . 58
4.6.3 Trapdoor (one-way) functions . . . 58
4.6.4 Beyond Diffie–Hellman . . . 59
4.6.5 Man-in-the-Middle (MITM) attack . . . 59
4.6.6 The need for trust (authentication) . . . 59
4.7 Summary . . . 60

Chapter 1
Introduction to Computer Security

1.1 Why a course on computer security?

When designing "classical" systems or programs, we usually aim to guarantee three properties:

- **Correctness**: for a given input, the program provides the expected output.
- **Safety**: well-formed programs cannot produce bad (even dangerous) outputs.
- **Robustness**: the system copes with errors, both in the input and during execution.

In all these cases, we try to anticipate what could go wrong and take it into account in the design. Computer security differs from these disciplines by one extra ingredient: the presence of an **adversary**, i.e., an entity that *actively and intelligently* tries to make the system fail, as opposed to a random fault or accidental error.

1.2 What is computer security?

Definition 1 (Computer security)**.**
Properties of a computer system must hold **in the presence of a resourced strategic adversary**.

Two elements are therefore central to any security analysis:

1. **Which properties** must be guaranteed?
2. **Against which adversary** (with which capabilities) must they be guaranteed?

1.2.1 Traditional properties: the CIA triad

Definition 2 (Confidentiality)**.**
Prevention of unauthorized disclosure of information.
Example: the adversary should not be able to read my bank statement.

Definition 3 (Integrity)**.**
Prevention of unauthorized modification of information.
Example: the adversary should not be able to change my bank balance.

Definition 4 (Availability)**.**
Prevention of unauthorized denial of service.
Example: the adversary should not be able to prevent me from accessing my bank account.

These three properties form the **CIA triad** (*Confidentiality, Integrity, Availability*), which must be known by heart: it comes up in almost every exercise in this course.

1.2.2 Not-so-traditional (but important) properties

Modern security goes well beyond the CIA triad. Notable examples include:

- **Authenticity**: guaranteeing that a piece of information or an entity is indeed what it claims to be.
- **Anonymity**: preventing the identification of the principal behind an action.
- **Isolation**: preventing one component of the system from affecting another.
- **Non-repudiation**: preventing a principal from denying having performed an action.

Remark 1.
These properties will be revisited and formalized in later chapters (authentication, anonymity, etc.). The list above is not exhaustive — there are many more complex properties relevant to modern security.

1.3 The security policy

To precisely define a security property, we must specify *what* it applies to. Two notions are introduced for this:

Definition 5 (Assets / objects)**.**
Anything with value (data, files, memory, etc.) that needs to be protected.

Definition 6 (Principals / subjects)**.**
People, computer programs, services, etc. that interact with the system. A principal **may not** contain the adversary.

Definition 7 (Security policy)**.**
A high-level description of the security properties that must hold in the system, in relation to assets and principals.

Property	**General definition**	**Example (principals / assets)**
Confidentiality	Prevention of unauthorized disclosure of information	authorized users may read a file
Integrity	Prevention of unauthorized modification of information	authorized programs may write a file
Availability	Prevention of unauthorized denial of service	authorized services can access a file

Table 1.1: Examples of security properties expressed in terms of principals and assets.

1.4 The adversary and the threat model

Definition 8 (Threat model)**.**
Describes the resources available to the adversary and their capabilities (observe, influence, corrupt, …).

A key point of the course: the adversary is **strategic**. This means they will choose *the best possible way* to use their resources to mount an attack that violates the security properties — one should never assume the adversary will act sub-optimally.

Remark 2.
Threat modelling is a **very hard task** in practice: underestimating the adversary's capabilities invalidates the security argument, while overestimating them can make the system impossible or too costly to build.

1.4.1 Key vocabulary to talk about the adversary

Term	Definition	Examples
Threat	The feared event, the goal of the adversary that we don't want to see materialize	A hacker wants to retrieve money by breaking into the bank's system; a student wants to learn my password by looking over my shoulder
Threat model	Technical term defining the adversary's capabilities	The adversary can observe my connection; the adversary can corrupt my machine; the adversary controls a bank employee
Harm	The bad thing that happens when the threat materializes	The adversary steals money; the adversary blocks access to the bank; the adversary learns my password; the adversary reads the message
Vulnerability	A specific weakness that could be exploited by adversaries interested in a variety of different assets	The banking API is not protected; the password appears in plain text on my screen

Table 1.2: Basic vocabulary for describing an adversary.

Remark 3 (Putting it all together)**.**
Computer security means guaranteeing that properties (defined by the **security policy**) hold in the presence of an adversary (described by the **threat model**). If the properties hold within that threat model, it means there is no exploitable **vulnerability** that could materialize a **threat**, and hence no **harm** occurs.

1.5 Securing a system: security mechanisms

Definition 9 (Security mechanism)**.**
A technical mechanism used to ensure that the security policy is not violated by an adversary within the threat model.

A security mechanism can combine:

- **Software** (programs),
- **Hardware**,
- **Maths** (cryptography),
- **Distributed systems**, **people**, and **procedures**.

Remark 4.
Security mechanisms can be *engineered*, just like any other part of a system.

Example 1 — Policy: ensure the log of transactions is not tampered with by a single employee. Mechanism: keep a copy of the log on multiple computers, such that no single employee has access to all of them.

Example 2 — Policy: ensure messages cannot be read by anyone but the sender and the receiver. Mechanism: encrypt the message before sending it.

1.5.1 Composing multiple mechanisms

Real systems are large and often require **several** security mechanisms combined together. There are two fundamentally different ways of composing them, and distinguishing them clearly is crucial:

Definition 10 (Defence in depth)**.**
The security policy is maintained **as long as at least one** mechanism remains effective ("OR" composition).

Definition 11 (Weakest link)**.**
The security policy is violated **if any one** mechanism fails ("AND" composition).

Remark 5.
Important point for exercises: **security does not necessarily increase linearly with the number of mechanisms**. Depending on how mechanisms are composed, adding one can either strengthen the system (defence in depth) or introduce a new point of failure (weakest link) — e.g., a poorly designed mechanism added "in series" can weaken an otherwise solid system.

1.5.2 Humans are part of the system

Humans are an integral part of the system, and are often directly targeted by the adversary:

- **Phishing** attacks and **social engineering**.
- Bad use of passwords: **weak** passwords, passwords **written down**, or passwords **repeated** across services.

Remark 6.
The fact that humans are often the "weakest link" does **not** mean the rest of the system should be neglected: all mechanisms must remain robust.

1.6 How do we show systems are secure?

A very important, asymmetric way of reasoning about security:

- **Attacker**: it is enough to find **one single** way to violate **one single** security property (within the threat model) to "win".
- **Defender**: must show that **no** adversary strategy can violate the security policy.

This asymmetry is what makes security hard: the defender must cover *every* case, while the attacker only needs *one* success.

> "One of the major problems right now is script kiddies. These are people who just download open source tools that are meant for good, and they point them at whatever they want, press 'Go,' and it fires a suite of exploits at a system hoping one of them will work." — Richard Moore, Security Specialist (IBM)

Definition 12 (A "secure" system)**.**
A system is said to be **secure** if an adversary constrained by a specific *threat model* **cannot** violate the security policy.

Remark 7.
The security of a system is therefore never absolute: it is always **relative to a given threat model**. A system may be secure against a weak adversary and no longer secure against a stronger one.

Definition 13 (Security argument)**.**
A rigorous argument (verbal or mathematical) that the security mechanisms in place are indeed effective in maintaining the security policy, subject to the assumptions of the threat model.

Remark 8 (For a threat model to be useful)**.**
The model **must constrain** the adversary — otherwise no security argument is possible (an adversary with unlimited capabilities can always break the system).

Remark 9.
Security arguments for the **composition** of several mechanisms are particularly hard to get right (cf. *defence in depth* vs *weakest link* above).

1.7 Security engineering

Designing a secure system typically follows three steps:

1. **High-level specification**
   - Define the architecture of the system (e.g., a high-level block diagram).
   - Define the security policy (principals, assets, security properties).
   - Define the threat model.
2. **Security design**
   - Select / design security mechanisms.
   - State the security argument: which controls maintain which properties?
3. **Secure implementation**
   - Implement the mechanisms.
   - Ensure they conform to the design model.

- Security testing.

Remark 10.
Following this order (specify *before* implementing) is essential: a mechanism added without a clear threat model and security argument risks protecting against nothing precise, or creating a false sense of security.

1.8 Summary

- Security problems always involve an **adversary**.
- The adversary is **strategic**: they will take the most damaging approach possible.
- The adversary's **capabilities** define a **threat model**.
- **Security mechanisms** aim at fulfilling a **security policy** within a given threat model.
- Showing that a system is secure requires providing a **security argument**.
- **Composition** of mechanisms is not trivial (*defence in depth* vs *weakest link*).
- Security is always **relative** to the adversary considered.

Lecture 2 — 2026-09-17: Principles

Chapter 2
Principles of Computer Security

2.1 Motivation

Since we cannot, in practice, prove that a system is free of flaws, the field of computer security relies instead on a set of **design principles**: rules of thumb that, when followed, tend to reduce both the number and the severity of security flaws.

Remark 11 (Historical reference)**.**
The principles presented in this chapter were introduced by J. Saltzer and M. Schroeder in *The Protection of Information in Computer Systems*, Proceedings of the IEEE (1975). Despite their age, they remain the foundation of modern security engineering practice: for example, they were used in 2018 by N. Papernot (Google Brain) to structure the threat model of machine learning systems in *A Marauder's Map of Security and Privacy in Machine Learning*.

There are **8** core principles from Saltzer and Schroeder, plus **2** extra principles borrowed from physical security that are also commonly used in computer security.

Remark 12.
These principles are **not** a blind checklist to tick off. They are tools to help weigh design decisions and trade-offs. Most real-world security failures come from a principle being improperly evaluated or ignored, rather than from a fundamentally new kind of attack.

2.1.1 Motivating example: the Heartbleed bug

[Heartbleed, CVE-2014-0160] In 2014, a critical vulnerability was found in OpenSSL, the library used to encrypt HTTPS traffic.

- The *Heartbeat* extension of TLS lets a client send a small piece of data and ask the server to echo it back, simply to check that the connection is still alive.
- The client also sends the *claimed length* of the data it is sending.
- **Bug**: the server never checked that the claimed length matched the actual length of the data received. An attacker could send 1 byte while claiming to send 64 000 bytes; the server would reply with the attacker's byte *plus* the next 63 999 bytes of whatever happened to sit in its private memory (potentially including private keys, passwords, or other users' data).
- The missing fix was a single bounds check: `if (request_size < actual_size) { error; }`.

Two structural reasons let this bug survive undetected for two years:

1. **Feature complexity**: the Heartbeat extension was a non-essential feature bolted onto TLS, creating a new attack surface that did not need to exist for the core function of TLS.
2. **Codebase complexity**: OpenSSL is a huge codebase (hundreds of thousands of lines of C and Perl), which makes manual audit extremely difficult.

This example already illustrates the first, and arguably most fundamental, principle: **keep it simple**.

2.2 The eight core principles

2.2.1 1 – Economy of mechanism

Definition 14 (Economy of mechanism)**.**
Keep the design of a security mechanism (and its implementation) **as simple and small as possible**.

Why? A security mechanism must be easy to **audit and verify**. Note that *operational testing is not appropriate to evaluate security*: passing functional tests only shows the system behaves correctly on the inputs tested, not that no adversarial input can break it (although penetration testing remains valuable as one tool among others).

Definition 15 (Trusted Computing Base (TCB))**.**
Every component of the system (hardware, firmware, software) on which the security policy relies.

The TCB is the only thing that must be *trusted* to operate correctly for the security policy to hold. This gives the only proper technical use of the verb "to trust" in security engineering: *"X trusts Y will do Z."*

Remark 13.
If something goes wrong **within** the TCB, the security policy may be violated. If something goes wrong **outside** the TCB, the security policy should still hold. The TCB must therefore be kept as small as possible, both to ease verification (economy of mechanism) and to reduce the attack surface.

2.2.2 2 – Fail-safe defaults

Definition 16 (Fail-safe defaults)**.**
Base access decisions on explicit **permission** rather than on **exclusion**.

In other words: if a decision procedure fails, is uncertain, or an error occurs, the system should default to the **safe** state (deny access), not attempt to "fix" the situation on the fly. Concretely, this means using a **whitelist** approach rather than a **blacklist** approach: a lack of permission is easy to detect and does not require anticipating every possible way something could go wrong.

- **Security door**: if no permission was granted, the door does not open.
- **Form input**: if a user has no permission to write into field X, the system does not silently write elsewhere; it refuses.

[MongoDB defaults] For a while, MongoDB's out-of-the-box installation had authentication **disabled by default** and bound to **all** network interfaces (`0.0.0.0`) instead of only the local loop-back (`127.0.0.1`). Attackers scanned the internet for open instances, connected without a password, stole or encrypted the data, and left ransom notes. This is a textbook violation of fail-safe defaults: the default configuration favored ease of use over safety, and many administrators never changed it.

Remark 14 (Ransomware)**.**
Ransomware denies the victim access to their own data (typically by encrypting it) and demands payment for the decryption key. The very first documented ransomware dates back to 1989 (the "AIDS Information" floppy disk attack); the phenomenon exploded with the arrival of cryptocurrencies, which make anonymous payment easy. Many ransomware epidemics (e.g., around 2017) directly exploited unsafe defaults such as the MongoDB case above.

2.2.3 3 – Complete mediation

Definition 17 (Complete mediation)**.**
Every access to **every** object must be checked for authority.

This principle is usually phrased in terms of a **reference monitor**: a component that mediates *all* actions of subjects on objects, checks them against the security policy, and may log them to an audit log.

[Streaming service authorization] Consider a streaming platform where users can subscribe to a "Gold" tier granting access to exclusive content.

- **Naive (fast) implementation**: the user's Gold status is checked only **once**, at login. The server then issues a session cookie such as `{'user': 'Alice', 'status': 'paid'}`, and every subsequent request only reads this cookie.
- **Attack**: Alice subscribes for one day, logs in (cookie says `paid`), then immediately unsubscribes. The database is correctly updated to `unpaid`, but her cookie is not re-checked. Alice can keep watching premium content until her session expires.

This is a direct violation of complete mediation: not *every* access to the object (the video) was checked against the current policy.

Remark 15 (Why complete mediation is hard to implement)**.**

- **Performance**: checking every single access can be very slow; there is an inherent trade-off between the time spent checking and the time spent actually using the resource.
- **Modern distributed systems**: a reference monitor can only mediate what it *sees* — if part of the system bypasses it (as in the caching example above), mediation is incomplete.

2.2.4 4 – Open design

Definition 18 (Open design)**.**
The design of a security mechanism should **not** need to be secret.

This principle has a long history predating computer security:

- **Kerckhoffs** (*La Cryptographie Militaire*, 1883): "The design of a system should not require secrecy."
- **Shannon** (*Communication Theory of Secrecy Systems*, 1949): "The enemy knows the system"; one should design systems assuming the adversary will immediately gain full familiarity with them.
- **Baran** (*Security, secrecy, and tamper-free considerations*, 1964): the "Paradox of the Secrecy About Secrecy" — without the freedom to expose a design to widespread scrutiny by people with diverse expertise, one increases the risk that significant weaknesses go unnoticed.

Remark 16.
Open design does **not** mean nothing is kept secret: it means the *algorithm* is public, while only well-defined, easily replaceable **key material** is kept secret. For example:

- **Cryptography**: only the key is kept secret, not the algorithm.
- **Authentication**: only the password is kept secret, not the authentication protocol.
- **Obfuscation**: only the random noise used is kept secret, not the obfuscation method.

Open design leads to better and easier auditing:

> **Linus' law** (E. Raymond, *The Cathedral and the Bazaar*, 1997): "Given enough eyeballs, all bugs are shallow."

This is more of a mantra than a guarantee: it requires genuinely many competent eyeballs, since the density of defects in real software is high. Relying on secrecy instead is unrealistic in practice and is a common way to end up with a bad threat model (*security through obscurity*). A famous failure of closed design is GSM encryption, whose secret algorithms were reverse-engineered and found to be weak.

[Deep Root Analytics leak, 2017] The personal data (names, addresses, birthdates, political profiling) of 198 million US voters, compiled by data firm Deep Root Analytics, was exposed online in a publicly accessible server with **no password and no authentication**. The only "protection" was that the URL was semi-secret. A security researcher found the URL and disclosed the issue; the 1.1 TB database had effectively been open to anyone on the internet. This is a direct case of security through obscurity failing.

[Scanning the whole internet is cheap] There are only $2^{32} \approx 4$ billion IPv4 addresses. As early as 2013, it was possible to scan every IPv4 address on a given port in about 3 minutes. Consequently, picking a "random" or non-standard port for a service does not hide it from a motivated adversary — it only adds negligible cost.

2.2.5 5 – Separation of privilege

Definition 19 (Separation of privilege)**.**
No single accident, deception, or breach of trust should be sufficient to compromise the protected information; **multiple, independent conditions** should be required to perform a sensitive action.

Remark 17.
A **privilege** is the ability granted to a user to perform an action with security consequences (e.g., create a file, access a device, write to a network socket).

Requiring two keys to open a safe, or two independent factors to authenticate, are classic instances of separation of privilege. This comes with trade-offs: **availability** (what if one key-holder is unavailable?), **responsibility** (who is accountable?), and added **complexity**.

[Corporate payment system] Consider a business payment system with principals *Employees* (submit orders), *Vendors*, and *Managers* (who can approve new vendors and approve orders, and inherit Employee rights). The security goal is that an attacker must not be able to steal money, under a threat model where the adversary can corrupt **at most one** principal.

If a single corrupted employee can (1) create a fake vendor, (2) submit a fake order for that vendor, and (3) approve the payment themselves, the entire attack can be carried out by one corrupted principal — there is no separation of privilege.

Fix: split the roles so that no single role can complete the whole attack chain:

- *Procurement* role: can only create/approve new vendors, cannot approve payments.
- *Finance Manager* role: can only approve payments for vendors already registered, cannot create new vendors.

Remark 18.
Separation of privilege is reminiscent of the "separation of powers" / "checks and balances" principle in political science.

2.2.6 6 – Least privilege

Definition 20 (Least privilege)**.**
Every program and every user of the system should operate using the **least** set of privileges necessary to complete the job.

Concretely: rights should be granted **as needed** and discarded **after use**. This limits damage control and minimizes high-privilege actions and interactions — it is the security analogue of the "need-to-know" principle.

Guest accounts at EPFL (limited-duration, limited-scope access), and the *data minimization* principle in data protection law (collect and retain only the data strictly necessary for the stated purpose), are both direct applications of least privilege.

2.2.7 7 – Least common mechanism

Definition 21 (Least common mechanism)**.**
Minimize the amount of mechanism common to, and depended on by, more than one user.

Remark 19.
This is closely related to economy of mechanism, but focuses specifically on **shared** mechanisms: "every shared mechanism represents a potential information path between users, and must be designed with great care so that it does not unintentionally compromise security."

- At the **design** level, interactions between users through a shared mechanism make the security design harder to validate.
- At the **implementation** level, interactions may lead to unintentional information leaks through *unintended channels*, e.g., a shared `/tmp` directory or a shared cache.

This principle concerns *mechanisms*, not *code*: reusable, well-tested code is generally good for security. The issue is the sharing (lack of isolation) of *data and state*, not code reuse itself.

Remark 20 (Reminder: symbolic links)**.**
A symbolic link ("symlink") is a shortcut file: when the operating system accesses it, it is automatically redirected to the real file or directory it points to.

[Violation via a shared `/tmp` directory] Consider three principals: (1) a root/admin program that predictably writes a log file with `echo "Service is starting..." > /tmp/starting.log`; (2) the root/admin logging subsystem; (3) an unprivileged user who can also write to `/tmp`. The security goal is to preserve the integrity of the logs written by the logging subsystem, under a threat model where the adversary can corrupt principal (3).

Attack: the unprivileged user creates, ahead of time, a symlink `ln -s /var/log/dmesg /tmp/starting.log`. When the root program later writes to `/tmp/starting.log`, it actually (over)writes `/var/log/dmesg`, an unrelated privileged log file.

This works because `/tmp` is a mechanism **shared** between low-privilege and high-privilege processes: exactly the setting least common mechanism warns against. (Modern Linux systems mitigate this specific `/tmp` case, but the same attack works if the shared, writable directory is elsewhere, e.g., under `/home/user`.)

2.2.8 8 – Psychological acceptability

Definition 22 (Psychological acceptability)**.**
The human interface must be designed for ease of use, so that users **routinely and automatically** apply the protection mechanisms correctly.

Three consequences:

- Security mechanisms should **not** make a resource harder to access than if the mechanism were absent (hide complexity).
- The (honest) user's **mental model** of the system must match the actual security policy and mechanisms.
- **Cultural acceptability**: not every mechanism is acceptable everywhere, e.g., face-recognition authentication is unsuitable in cultures where faces are covered, and requiring a register of everyone sleeping in a dorm raises different acceptability concerns depending on context.

[Amazon S3 permission confusion] Amazon S3 ("Simple Storage Service") stores data as objects inside containers called *buckets*. Psychological acceptability is not only about end users: system administrators configuring a bucket are also "users" of a UI, and that UI can mislead them.

S3's permission UI historically offered an option to grant access to "Any Authenticated AWS User." Administrators commonly read this as "any authenticated user of *my* organization/account," while it actually meant "any person on Earth with *any* AWS account," which is free to create. This mismatch between the mental model and the actual policy caused several major data leaks starting in 2017. Amazon later (2023) introduced an additional layer of fail-safe defaults, blocking public access by default.

Remark 21 (Safer defaults are not free)**.**
Tightening defaults for security (e.g., Amazon's 2023 change) can break workflows that legitimately relied on the old, more permissive behavior, generating user frustration. This illustrates that fail-safe defaults and psychological acceptability can be in tension, and trade-offs must be weighed explicitly.

2.3 Two extra principles (from physical security)

2.3.1 9 – Work factor

Definition 23 (Work factor)**.**
Compare the **cost** of circumventing a security mechanism with the **resources** available to a potential attacker.

This principle helps refine the threat model: a mechanism need not resist an unlimited adversary, only one bounded by the threat model. In practice, quantifying the work factor is difficult: how does one price the cost of bribing/compromising an insider, the cost of finding a given bug, or the monetary value an attacker could extract?

2.3.2 10 – Compromise recording

Definition 24 (Compromise recording)**.**
Reliably record that a compromise has occurred, in place of (or in addition to) more elaborate mechanisms that try to completely prevent loss.

Keeping tamper-evident logs can enable recovery of integrity even when prevention fails. However, logging is not a silver bullet:

- Logging does not guarantee the compromise is detected.
- If confidentiality mechanisms were the ones compromised, logging does not help recover what was already leaked.
- Logs themselves must maintain integrity (what stops the log from being tampered with?).
- Logs can themselves become a vulnerability, e.g., a privacy risk if they contain sensitive data.
- Logging the logs raises its own availability concerns.

2.4 Applying the principles: a machine learning example

As a sign of how durable these 1975 principles are, they are routinely reused to structure entirely new domains. For instance, N. Papernot's 2018 threat-modeling of machine learning security maps directly onto several of them:

- **Least privilege**: let a model learn as little as possible, so that sensitive information cannot later be extracted from it.
- **Least common mechanism**: obtain labelled samples from diverse, independent origins rather than a single shared source.
- **Psychological acceptability**: users must be able to understand *why* a model classifies or misclassifies a given input.
- **Work factor**: the cost of an attack (e.g., number of queries to an API) determines its practical relevance.
- **Compromise recording**: ideally, one would like to log all internal steps of the algorithm to detect compromise.

2.5 Summary

> "Since no one knows how to build a system without flaws, the alternative is to rely on eight design principles, which tend to reduce both the number and the seriousness of any flaws: economy of mechanism, fail-safe defaults, complete mediation, open design, separation of privilege, least privilege, least common mechanism, and psychological acceptability." — Saltzer and Schroeder, 1975

- **Economy of mechanism**: keep the design (and implementation) as simple and small as possible; keep the TCB small.
- **Fail-safe defaults**: base access on permission (whitelist), not exclusion; on failure, default to the safe state.
- **Complete mediation**: verify *every* access to *every* object, every time.
- **Open design**: the design should not need to be secret; only well-defined key material should be.
- **Separation of privilege**: no single compromised principal should be able to complete a sensitive action alone.
- **Least privilege**: operate with the minimum privileges necessary, granted as needed and revoked after use.
- **Least common mechanism**: minimize mechanisms shared between users, to avoid unintended information paths.
- **Psychological acceptability**: the security mechanism must be easy enough to use that honest users apply it correctly and routinely.
- **(Extra) Work factor**: weigh the cost of an attack against the attacker's resources.
- **(Extra) Compromise recording**: when prevention fails, at least reliably detect and record that a compromise occurred.

Remark 22.
These principles are guidelines, not proofs. Use them as tools to identify and weigh design trade-offs when building or auditing a security mechanism — not as a checklist that, once ticked, guarantees security.

Chapter 3
Access Control

3.1 Introduction to access control

3.1.1 What is access control?

In the physical world, access control is everywhere: a key in a lock, a badge on a reader, a turnstile in a metro station.

The digital world has exactly the same needs, and we will see that the mechanisms are conceptually similar.

Definition 25 (Access control)**.**
A security mechanism that ensures that **all accesses and actions on objects by principals are within the security policy**.

An access control system must be able to answer questions such as:

- Can Alice read the file `/users/Bob/readme.txt`?
- Can Bob open a TCP socket to `http://www.abc.com/`?
- Can Charlie write to row 15 of the table `GRADES`?

The answer to each question is binary: either the access is **authorized** (the principal *has permission*), or it is **unauthorized** (*access denied*). The goal is that **only events within the security policy** actually happen.

Remark 23.
Recall the vocabulary of Chapter 1: the *principals* (subjects) are the entities acting on the system, the *assets* (objects) are the things to protect, and the *security policy* says which principal may do what on which asset. Access control is the mechanism that *enforces* this policy.

3.1.2 Why is access control so important?

Access control is the **first line of defence**. As a consequence, it is used at *every* layer of a system:

Layer	**Examples of what access control protects**
Applications	Online social networks, e-mail servers, cloud storage
Middleware	Database management systems (DBMS)
Operating system	Files, directories, ports, …
Hardware	Memory, registers, privilege levels

Table 3.1: Access control is used at every layer of the system stack.

3.1.3 Where does access control fit? Authentication vs. authorization

Access control is usually split into two steps:

1. **Authentication**: the system must *bind the actor to a principal*. A principal is an abstract entity that is authorized to act (a user, a connection, a process, …).
2. **Authorization**: the system must *decide whether the principal is authorized* to perform the requested action on the requested object.

Remark 24.
The mechanisms that perform authentication **and** authorization are part of the **Trusted Computing Base** (TCB): if they fail, the security policy may be violated.

3.1.4 Implementing access control: the reference monitor

What NOT to do: "checks soup". A naive implementation sprinkles checks all over the program, each one implementing the policy *in-line*:

```
# some code that needs to access file3.txt
if (action == read) and ((userID == Alice) or (userID == Bob)):
    open(file3.txt, 'r')
elif (action == write) or (userID == Bob):
    open(file3.txt, 'w')
else:
    print("The user does not have access to file3.txt")
```

This is a bad design: the policy is scattered everywhere, which makes it hard to audit, hard to change, and very error-prone. (The example above even contains a bug: the `write` branch uses an `or`, so *anybody* can write the file!) It is the opposite of *economy of mechanism*.

What you SHOULD do: systematic calls to a reference monitor. Throughout the program, add checks that **call a central monitor**. The checks state which authorization is required and provide *evidence* about the principal and the object; the central subsystem (the **reference monitor**) decides whether the check passes.

```
if ( subject.isPermitted("user:delete:jsmith") ) {
    // delete the 'jsmith' user
} else {
    // don't delete 'jsmith'
}
```

The application does not contain the policy: it only asks the monitor.

Remark 25.
The reference monitor is how **complete mediation** is put in practice (every access goes through the monitor), and keeping it small and central follows **economy of mechanism**. The slides ask, with a question mark, whether this violates **least common mechanism**: a central monitor *is* a mechanism shared by all users. This is a typical example of *tension between principles*, which must be weighed explicitly rather than ticked off blindly.

3.1.5 Who decides the access policy? DAC vs. MAC

There are two fundamentally different answers to the question "who defines who can access what?".

	Discretionary (DAC)	**Mandatory (MAC)**
Who sets permissions	The **owner** of each object assigns permissions	A **central security policy** assigns permissions
Key idea	Ownership of resources	Organizations with a need for central control
Typical uses	Windows, Linux, macOS; social networks; cloud file sharing	Military (focus on confidentiality); hospitals (confidentiality *and* integrity); banking (focus on integrity)

Table 3.2: Discretionary vs. mandatory access control.

3.2 Discretionary Access Control (DAC)

Definition 26 (Discretionary Access Control)**.**
An access control approach in which the **owners of the objects establish the permissions** on them.

3.2.1 Historical motivation: Lampson's protection

DAC policies were conceptualized by B. Lampson in *Protection* (Proc. 5th Princeton Conf. on Information Sciences and Systems, 1971; reprinted in ACM Operating Systems Review 8(1), 1974).

The original motivation for protection mechanisms in computers was to keep *one user's malice or error* from harming another user. Harm can be inflicted by:

a) destroying or modifying another user's data;
b) reading or copying another user's data without permission;
c) degrading the service another user gets (e.g., using up all the disk space or getting more than a fair share of the processing time; an extreme case is crashing the system).

Lampson adds that all these reasons are just as strong if the word "user" is replaced by "*program*": a program (e.g., downloaded malware) can be as dangerous as a malicious user.

These three kinds of harm map directly onto the CIA triad: (b) is a confidentiality violation, (a) an integrity violation, (c) an availability violation.

3.2.2 The Access Control Matrix

In a real system there are many subjects, many objects, and many combinations of permissions between them. How can we reason about them? DAC policies are conceptualized as an **access control matrix**.

Definition 27 (Access control matrix)**.**
An **abstract representation of all permitted triplets** (subject, object, access right) within a system. Rows are subjects, columns are objects, and each cell contains the set of operations the subject is allowed to perform on the object.

- **Subjects** (principals): entities within an IT system: a user, a process, a service.
- **Objects** (assets): resources that (some) subject may access or use: a file, a folder, a row in a database, the system's memory, a machine on the network, a printer, a page of a website.

- **Operations**: in the abstract, subjects can *observe* and/or *alter* objects: `read`, `write`, `append`, `execute`.

Let $S = \{\text{Alice}, \text{Bob}\}$, $O = \{\text{file1}, \text{file2}, \text{file3}\}$ and $A = \{\text{read}, \text{write}\}$.

	file1	**file2**	**file3**
Alice	read, write		read
Bob		read, write	read, write

Table 3.3: An access control matrix.

Can Alice read file1? *Yes.* Can Bob write file1? *No* (empty cell: no permission). Can file3 be written by Alice? *No* (she only has `read`).

Remark 26 (Fail-safe defaults)**.**
An empty cell means *no permission*. This is the whitelist approach of fail-safe defaults: everything that is not explicitly granted is denied.

Why the matrix is not implemented directly

The access control matrix is an **abstract concept**, not meant for direct implementation. With f files and u users it takes $O(f \cdot u)$ space. For a system with 629 601 files:

Setting	**Matrix size**
1 bit per file, 1 user	$\approx 78\,\text{KB}$
3 bits per file (r/w/x), 1 user	$\approx 236\,\text{KB}$
3 bits per file, 10 users	$\approx 2.36\,\text{MB}$

Beyond raw size, there are more issues:

- The matrix is usually **very sparse**, hence wasteful.
- It is **inefficient to access**: it would have to be kept in fast memory.
- **Extensibility**: what happens when a file or a user is added?

The matrix can be stored in two natural ways: by *column* (permissions attached to objects: **ACLs**) or by *row* (permissions attached to subjects: **capabilities**). Role- and group-based access control are ways of *factoring* the subjects.

3.2.3 Access Control Lists (ACLs)

Definition 28 (Access Control List)**.**
An implementation of the access control matrix that **associates permissions to objects**: each object stores the list of (subject, rights) pairs that are allowed to access it. **Blank cells are not stored.**

For the matrix above:

$$\begin{aligned}
&\text{file1} : \{(\text{Alice}, \text{read/write})\} \\
&\text{file2} : \{(\text{Bob}, \text{read/write})\} \\
&\text{file3} : \{(\text{Alice}, \text{read}), (\text{Bob}, \text{read/write})\}
\end{aligned}$$

Advantages	Drawbacks
Can be stored close to / with the resource	Difficult to check at runtime
Easy to determine *who can access a resource*	Difficult to audit *all the rights of a user*
Easy to *revoke rights by resource*	Difficult to remove all permissions from a user (better remove their authentication!)
	Difficult delegation

Table 3.4: Pros and cons of ACLs.

3.2.4 Role Based Access Control (RBAC)

Systems have **too many subjects**, and they come and go. This leads to large, dynamic ACLs that are painful to maintain. However, subjects are often *similar to each other*: e.g., a doctor has the same privileges as another doctor. RBAC exploits this:

Definition 29 (Role Based Access Control)**.**

1. **Assign permissions to roles**;
2. **assign roles to subjects**;
3. subjects **select an active role**: they hold the permissions of the active role.

Roles add a level of indirection: when an employee changes job, we change their role assignment rather than editing the ACL of every object.

Problems of RBAC.

1. **Role explosion**: the temptation to create very fine-grained roles removes the benefit of RBAC (we end up with roughly as many roles as subjects).
2. **Limited expressiveness** of simple RBAC: it is hard to implement least privilege precisely, and some roles are *relative*: "Alice's doctor" versus "any doctor".
3. **Separation of duty is difficult**: e.g., "two doctors are needed to authorize a procedure". The RBAC mechanism itself needs to ensure that the two doctors are *distinct*, which a plain role-to-permission mapping cannot express.

3.2.5 Group Based Access Control

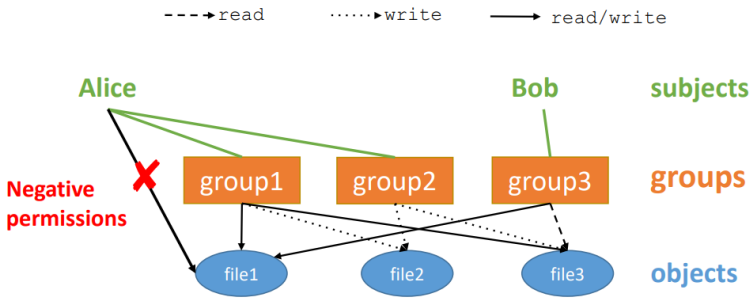
Another way to factor subjects: some permissions are **always needed together** (e.g., access to sockets and to the network interface go hand in hand).

Definition 30 (Group Based Access Control)**.**

1. **Assign permissions** to access objects **to groups**;
2. **assign subjects to groups**;
3. subjects hold **the permissions of all their groups**.

Remark 27 (Groups vs. roles)**.**
The difference with RBAC is subtle but important: in group-based access control a subject has the *union* of the permissions of *all* its groups at all times, whereas in RBAC the subject activates *one role at a time* and holds only its permissions, which helps enforce least privilege.

Negative permissions. To express fine-grained policies, group-based systems often add **negative permissions** (explicit denials), e.g., "everyone in group1 may read, except Alice".



Remark 28 (What do we check first?)**.**
Negative permissions must be checked first. Otherwise a positive permission obtained through another group could grant the access before the denial is ever seen. Evaluating denials first is also consistent with **fail-safe defaults**. (Windows does exactly this; see below.)

3.2.6 Capabilities

Definition 31 (Capability)**.**
An implementation of the access control matrix that **associates permissions to subjects**: each subject holds the list of (object, rights) pairs it is allowed to use. A capability is an *unforgeable* reference to an object that carries the right to use it; holding it is what gives the authority.

For the same matrix:

$$\text{Alice} : \{(\text{file1}, \text{read/write}), (\text{file3}, \text{read})\}$$
$$\text{Bob} : \{(\text{file2}, \text{read/write}), (\text{file3}, \text{read/write})\}$$

Again, blanks are not stored.

Advantages	**Drawbacks**
Can be stored *with the subject* (portable!)	*Revoking* the permission on one object is hard
Easy to audit *all the permissions of a subject*	*Transferability*: once a capability is given, how can we prevent sharing?
Delegating is "simple" (hand over the capability)	*Authenticity*: how can we check that a capability is genuine (not forged)?

Table 3.5: Pros and cons of capabilities.

Remark 29 (ACLs vs. capabilities: mirror images)**.**
The pros and cons are exactly mirrored. ACLs make *per-object* questions easy (who can access this file? revoke access to it) and *per-subject* questions hard. Capabilities make *per-subject* questions easy (what can Alice do? delegate) and *per-object* questions hard. This mirrors the two ways of storing a sparse matrix: by column or by row.

3.3 Ambient authority and the confused deputy

3.3.1 Ambient authority

Definition 32 (Ambient authority)**.**
A subject uses **ambient authority** if, for an action to succeed, it **only needs to specify the operation and the names of the involved objects**. The subject holding the authority is *implicit*.

`open("file1", "rw")`: the subject is missing from the call; it is implicitly the *owner of the process*.

- **Advantage**: usability. There is no need to repeat the subject all the time.
- **Drawbacks**: **least privilege becomes harder to enforce** (the process uses *all* the authority of its owner for *every* action), and the program itself **cannot check permissions** on behalf of the party that actually requested the action. This leads to the confused deputy problem.

3.3.2 The confused deputy problem

Definition 33 (Confused deputy problem)**.**
A problem of ambient authority: a **privileged program can be tricked into misusing its authority** on behalf of a less privileged requester.

[The pay-per-use compiler] (The classic example, due to N. Hardy.) A compiler is offered as a pay-per-use service. It receives two file names `(input, output)`. It compiles the program `input`, then:

- writes the **usage** (what the user owes) into the file `bill`;
- writes the **errors** into the file `output`.

The compiler's own access rights are those of the service. The ACLs are:

$$\begin{aligned} \texttt{input} &: \{(\text{Alice}, \text{write}), (\text{Compiler}, \text{read})\} \\ \texttt{output} &: \{(\text{Alice}, \text{read}), (\text{Compiler}, \text{read/write})\} \\ \texttt{bill} &: \{(\text{Alice}, \text{read}), (\text{Compiler}, \text{read/write})\} \end{aligned}$$

Can Alice change the bill and avoid paying? Not directly: Alice only has `read` on `bill`. But Alice calls the compiler with arguments `(input, bill)`, i.e., she chooses `bill` as the *output* file. The compiler compiles `input` and writes the errors into "`output`" = `bill`. The compiler is allowed to write `bill`, so the write succeeds and **the bill is corrupted**.

Why does this happen? The compiler *never checks* whether Alice herself would be allowed to write the file she designated as output: it uses its own (ambient) authority to do so. The *designation* of the object (the name chosen by Alice) is separated from the *authority* used to act on it.

How to avoid confused deputies. This is a real problem, because ambient authority is used for convenience in many real systems: OS services, web servers, …Solutions:

1. **Re-implement access control in the privileged process** (e.g. before writing in *output*, the compiler check if output = bill);
2. **let the privileged process check the authorization of Alice** (not only its own);
3. **use capabilities**.

[The compiler with capabilities] The compiler holds a capability to the file `bill` (for its own use). To compile, Alice must *give* the compiler a capability to the debugging file `output`. Alice only holds a read capability on `bill`, so she **cannot hand over a capability for writing on `bill`**. Since the authority travels together with the name of the object, nobody can be confused.

Remark 30 (Exam hints on the confused deputy)**.**
Do not just throw the keyword "confused deputy" (or "ambient authority") at a question: link it to the problem at hand. Identify (1) the privileged *deputy*, (2) the less privileged *requester* who controls what the deputy is asked to do, and (3) the action that the requester could not perform alone but that the deputy performs with its own authority. In a past MCQ about a room booking system, the maintenance team (the deputy) cancelling all bookings on a *wrong report* was debated precisely because the question must be read in terms of these three elements.

3.4 Summary of the DAC concepts

- **Discretionary Access Control**: owners establish permissions.
- Conceptualized as an **access control matrix** (abstract; not implemented directly).
- Implemented in two flavours: **access control lists** (permissions associated to objects) and **capabilities** (permissions associated to subjects).
- Roles and groups factor many subjects into a few classes of subjects.
- When relying on access control, always think about **confused deputies**.

3.5 DAC in practice: Linux (UNIX) and Windows

Many of the systems we use every day rely on DAC: social networks, cloud file-sharing systems, and operating systems.

3.5.1 UNIX: principals and groups

- **User identities** (UIDs) and **group identities** (GIDs): originally 16-bit, now 32-bit numbers. Some UIDs are special (e.g., 0 for root, and the special "nobody" user).
- **User information**: each user has their own directory `/home/username`. User accounts are listed in `/etc/passwd`, one line per user with the format

  ```
  username:password:UID:GID:info:home:shell
  ```

- Users belong to **one or more groups**: a *primary* group (given in `/etc/passwd`) and other groups (listed in `/etc/group`).

Security architecture

- **Everything is a file** (regular files, directories, devices, …), so one mechanism protects everything.
- Each user **owns** a set of files.
- Each file has a simple **Access Control List** expressing the policy for that file.
  - The owner can modify the permissions of the file, but **cannot give away ownership**.
  - System files are owned by special users that can perform system operations.
- All processes launched by a user run **with that user's privileges**: this is **ambient authority**!

File ACLs: the 9 permission bits

Each file is assigned an **owner UID** and a **GID**, and has **9 permission bits**: 3 actions (**r**ead, **w**rite, e**x**ecute) for 3 classes of subjects (**owner**, **group**, **other**). Besides these there are 3 special attributes: **suid**, **sgid** and **sticky**.

```
drwxrwxr-x 1 catronco catronco 4096 Sep 16 14:23 exampledir
-rwxrwxrw- 1 catronco catronco 8600 Sep 15 15:20 hello
-rw-rw-rw- 1 catronco catronco  150 Sep 15 15:14 hello.c
-rw-rw--w- 1 catronco catronco   45 Sep 15 15:07 test1.txt
```

Reading a line from left to right: the **type** (`d` for directory, `-` for a regular file), the three **owner** bits, the three **group** bits, the three **other** bits, the number of **links**, the **owner**, the **group**, the **size**, the **last modification** date and the **file name**. For example, `-rw-rw--w-` means: owner may read and write, group may read and write, others may only write.

Bit	**On a file**	**On a directory**
`r` (read)	Read the content	**List** the files in the directory
`w` (write)	Modify the content	**Add** (create) files
`x` (execute)	Run the file as a program	**Traverse** the directory (`cd`, and access what is inside by path)

Table 3.6: Semantics of the permission bits on files vs. directories.

Different semantics for files and directories.

Remark 31 (Directory permissions matter on the whole path)**.**
To access `/a/b/c.txt` one needs the `x` (traverse) permission on `/`, `/a` and `/a/b`, on top of the right permission on `c.txt` itself. Creating, deleting or renaming a file is governed by the `w` (and `x`) bits of the *containing directory*, not of the file. This is a classic trap in exercises.

Changing permissions. The owner can change the permissions of a file with `chmod`, either symbolically (`+r`, `-w`, …) or in octal. In octal, read = 4, write = 2, execute = 1 for each of the three triplets, so `666` = `rw-rw-rw-` and `662` = `rw-rw--w-`. The special bits are written with a fourth leading digit: `4000` for suid, `2000` for sgid and `1000` for sticky. For example, `+t` or `1666` sets the sticky bit and `+s` or `4666` sets suid.

How UNIX checks an access

The kernel compares the **UID/GID of the process** trying to perform the action with the **state of the file** (owner, group, mode bits). **The order matters**:

1. If the UID says you are the **owner**: check the **owner** bits.
2. Otherwise, if your **group** is the file's group: check the **group** bits.
3. Otherwise, check the **other** bits.

Remark 32.
Only the *first matching class* is used. If you are the owner, the owner bits apply even if the group or other bits are more permissive (so an owner can be *denied* an access that his group is granted). The one exception is the **root user, who is never denied access**.

Super users: root

- Special **root** user account, with **user ID 0**.
- Accesses system files and performs special operations.
- Can access anything: (almost all) security checks are disabled.
- **root is in the TCB!**

Never log in as root (some distributions even assign it no password). Use the `sudo` or `su` commands instead. This is the least privilege principle at work: operate as an ordinary user and elevate only when needed.

Remark 33 (`su` vs. `sudo`)**.**
The slide asks about the difference. Briefly: `su` ("switch user") opens a session as another user and requires *that user's* password; `sudo` runs a *single command* with the privileges of another user (root by default) after the *caller* authenticates with their own password, if the policy (`/etc/sudoers`) allows it, and it **logs** each use (compromise recording). In `sudo su catronco`, `su` runs as root, which does not need `catronco`'s password.

Normal users also need to access **system services**, but these services must run with system privileges. This is solved with the **suid/sgid** mechanism.

Special rights: suid and sgid

Definition 34 (Setuid and setgid)**.**
The **setuid** and **setgid** bits indicate that an executable file is run not with the privileges of the user who launches it, but with the privileges of the file's owner user (setuid) or owner group (setgid).

This is especially useful for programs that need root privileges while respecting **least privilege**: instead of giving the user root, the user is given a single, well-defined program that runs with elevated privileges. The typical example is changing one's password:

```
ls -l /bin/passwd
-rwsr-xr-x. 1 root root 27768 Aug 20 2020 /bin/passwd
```

The `s` in place of the owner's `x` indicates the setuid bit. Any user can run `passwd`, which runs as root and can therefore write the protected password file, but only in the way the program allows.

Remark 34 (Setuid root programs are dangerous)**.**
How do you know that a suid program does what it is meant to do, **and only what it is meant to do**? A setuid-root program runs with full root privileges, so any bug in it can be exploited by

the user who launches it. **Setuid root programs are therefore part of the TCB** and must be kept small and audited (economy of mechanism). Imagine what would happen if a general-purpose interpreter such as `python2.7` were setuid root: anyone could run arbitrary code as root. (See Chen, Wagner, Dean, *Setuid Demystified*, USENIX Security 2002; Kamp and Watson, *Jails: Confining the omnipotent root*, 2000.)

Remark 35 (Exam pitfalls on setuid)**.**
Past midterm feedback highlights the following errors:

- **Setuid applies to executables**, i.e., to the *program*, not to a (non-executable) data file.
- Use the **correct notation**: a program owned by `dave` that members of group `managers` may run and others may read is `-rwsr-xr--`.
- Do *not* "fix" a permission problem by making a sensitive file readable/writable by everybody: this removes any notion of access control on it and violates several security principles.

[Exam-style: emergency deletion program] Tropyota wants the CEO Carla (group `managers`) to be able to run an emergency program deleting the secret plans, which only the `designers` may read or modify. The configuration is

```
-rwxr-xr-- dave managers   program_to_delete_plans
-rw-rw---- dave designers  hybris_plans.dwg
```

Does it work? No: Carla can *execute* the program (group `managers` has `r-x`), but with ambient authority the process runs *with Carla's privileges*, and Carla (not in `designers`) has no access to the plans. **Fix**: set the **setuid bit on the program**, giving `-rwsr-xr--`, so that it runs with the privileges of its owner Dave, who can access the plans.

Least privilege? Still not satisfied: *every* manager (not only the CEO) can run the program, and the program runs with all of Dave's privileges, which is more than strictly necessary.

Special rights: the sticky bit

The sticky bit (`chmod +t`) is also called the **restricted deletion bit**.

- **On directories**: it prevents unprivileged users from *removing or renaming* a file in the directory unless they own the file. Example: the `/tmp` folder, which is writable by everyone, but where users can only delete or rename *their own* files.
- **On files**: historically, it kept a program in swap for faster loading. On current Linux, the bit is ignored for files.

Remark 36.
Recall the `/tmp` symlink attack of the *least common mechanism* example: `/tmp` is a shared mechanism. The sticky bit limits what users can do to one another's files there, but sharing a writable directory remains risky.

Special user: nobody

`nobody` is a special user (UID -2 in the slides) that **owns no files and belongs to no group of users**. It is a safer user to run code you do not know or trust (particularly obfuscated code), since it **limits the damage** if the code misbehaves or gets compromised: another application of least privilege.

3.5.2 Windows

- **Principals**: users, machines, groups, …
- **Objects**: files, Registry keys, printers, …

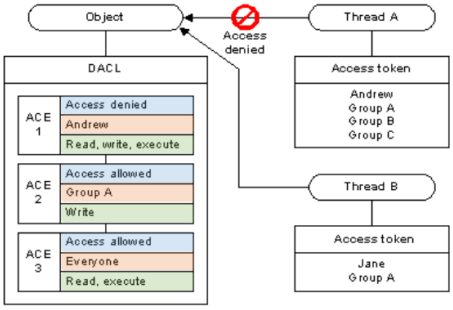
Access control works as follows:

- Each object has a **Discretionary Access Control List (DACL)**.
- Each process (or thread) has an **access token** containing: the *login user account* (the process "runs as" this user), *all the groups* of which the user is a member (recursively!), and *all the privileges* assigned to these groups.
- When a process **creates a handle to an object**, the DACL of the object is compared with the process' access token.

The DACL. A DACL is a list of **Access Control Entries (ACEs)**. Each ACE has:

- a **type**: negative (access denied) or positive (access allowed);
- a **principal**;
- the **permissions**, which are **more fine-grained than in UNIX**;
- flags and others.

List of Access Control Entries (ACEs)



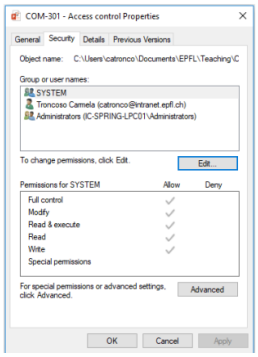
Type: negative / positive

Principal

Permissions: more fine grained than UNIX

+ Flags and others…

Least Privilege by default
Run as administrator



Remark 37 (Why negative first?)**.**
ACEs are evaluated *in order*, and **negative ACEs are placed first**: an explicit denial must win over an allowance obtained through another entry (for instance, through a group). The same reasoning as for negative permissions in group-based access control applies.

Least privilege by default. Windows encourages least privilege through "*Run as administrator*": even administrators work with a restricted token and elevate only when needed.

3.5.3 Comparison UNIX vs. Windows

	UNIX	**Windows**
Per-object list	9 permission bits (owner/group/other)	DACL: list of ACEs (type, principal, permissions)
Granularity	3 actions (r, w, x)	More fine-grained permissions
Denials	Implicit (first matching class decides)	Explicit negative ACEs, evaluated first
Subject side	UID, GID(s) of the process	Access token (user, all groups recursively, privileges)
Elevation	root, `sudo`/`su`, suid/sgid	"Run as administrator"

Table 3.7: DAC in UNIX and Windows.

3.6 Summary

- **Access control** ensures that all accesses of principals on objects are within the security policy; it is the **first line of defence** and is used at every layer (application, middleware, OS, hardware).
- It is split into **authentication** (bind the actor to a principal) and **authorization** (decide whether the principal may act); both are in the **TCB**.
- Do not write "checks soup": call a **reference monitor** (complete mediation, economy of mechanism).
- **DAC**: owners decide the permissions (Windows, Linux, macOS, social networks). **MAC**: a central policy decides.
- The **access control matrix** (subjects $\times$ objects $\rightarrow$ rights) is an abstract model, too big and sparse to implement directly.
- **ACLs**: permissions attached to objects (easy to see who accesses a resource, hard to audit a user). **Capabilities**: permissions attached to subjects (easy to audit and delegate, hard to revoke).
- **RBAC** (roles, one active role) and **groups** (union of all groups, negative permissions checked first) reduce the management cost of many subjects. RBAC suffers from role explosion, limited expressiveness and difficult separation of duty.
- **Ambient authority** is convenient but makes least privilege harder and causes the **confused deputy problem**. Solutions: re-check authorization in the privileged process, or use capabilities.
- **UNIX**: UIDs/GIDs, 9 permission bits (owner, group, other), check order owner $\rightarrow$ group $\rightarrow$ other, root never denied, directories have different semantics (list/add/traverse), **suid/sgid** (run with the owner's privileges; dangerous, in the TCB), **sticky bit** (restricted deletion, e.g., `/tmp`), **nobody** (safe user for untrusted code).
- **Windows**: DACL = list of ACEs (negative/positive, principal, fine-grained permissions), compared with the access token of the process; negative entries first.

3.7 From DAC to MAC

3.7.1 Recall: who decides the policy?

We studied **Discretionary Access Control (DAC)**, where the *owners* of objects assign the permissions. This lecture covers the other family:

Definition 35 (Mandatory Access Control)**.**
An access control approach in which **a central security policy assigns the permissions**. Access to, and operations on, resources are determined by the security policy:

- an "owner" **may not exist**, or **may not have the power** to set permissions against the policy;
- the security policy **must be enforced despite subjects trying to subvert it**.

Remark 38.
The second point is the crucial difference with DAC. Under DAC, a malicious program running with Alice's privileges can simply copy Alice's secret file into a public file, or `chmod` it, since Alice is the owner. Under MAC, *neither Alice nor her programs* can make the information flow somewhere the central policy forbids.

This lecture is theoretical on purpose: the goal is to understand basic concepts and principles of security design that will **outlast current technology**.

3.7.2 Security models

Definition 36 (Security model)**.**
A **design pattern** for a specific security property or set of properties.

When faced with a standard security problem, **use a well-known model** rather than inventing your own (the same philosophy as "do not roll your own crypto"). However, many aspects are *not* covered by the model:

- who are the **subjects**?
- what are the **objects**?
- what **mechanisms** are used to implement it?

The devil is in the details! A model only tells you what the rules are; mapping a real system onto the model (and implementing the mapping correctly) is where things go wrong.

This lecture presents three models:

Model	**Protects**	**Typical setting**
Bell–La Padula (BLP)	Confidentiality	Military, government
BIBA	Integrity	Banking, commerce, OS integrity
Chinese Wall (Brewer–Nash)	Conflicts of interest (C & I)	Financial sector, consulting

Table 3.8: The three MAC security models of this chapter.

3.8 Bell–La Padula (BLP): protecting confidentiality

D. Bell and L. LaPadula, *Secure computer systems: Unified exposition and Multics interpretation*, MITRE Technical Report ESD-TR-75-306, 1976.

3.8.1 Subjects, objects and access rights

Subjects S and objects O are each associated with a **level of confidentiality**. Subjects' access rights are defined by four attributes:

Right	Meaning	Observe?	Alter?
execute	The subject cannot see or modify the object, but can run it	no	no
read	The subject can only see the object, but cannot modify it	yes	no
append	The subject cannot read the object, but can attach new content to it	no	yes
write	The subject can see the object, add content and modify existing content	yes	yes

Table 3.9: The four BLP access rights.

These access rights are defined in an **access control matrix** (as in DAC, see the ds-property below).

Remark 39 (Observe vs. alter)**.**
Keep this classification in mind: **read** and **write** both *observe*; **append** and **write** both *alter*. Write is therefore constrained by *both* BLP rules, which is why it ends up only allowed at the subject's own level.

3.8.2 Security levels of objects: classification

Definition 37 (Security level)**.**
A security level is a pair

$$\text{Security Level} = (\text{Classification}, \{\text{set of categories}\})$$

where

- the **classification** is a label from a **total order** (e.g. Unclassified $<$ Confidential $<$ Secret $<$ Top Secret);
- the **categories** (or *compartments*) group objects with a common topic (e.g. Nuclear, NATO, Crypto).

Each object has a security level: it has a label and belongs to zero, one or more categories.

Categories implement **need-to-know**: a general with Top Secret clearance in the category NATO should not see Top Secret Nuclear documents unless he also has the Nuclear category.

3.8.3 The dominance relationship

Definition 38 (Dominance)**.**
A security level (l_1, c_1) **dominates** (l_2, c_2), written $(l_1, c_1) \succeq (l_2, c_2)$, if and only if

$$l_1 \geq l_2 \qquad \text{and} \qquad c_2 \subseteq c_1.$$

Both conditions must hold: a higher label is useless if a category is missing.

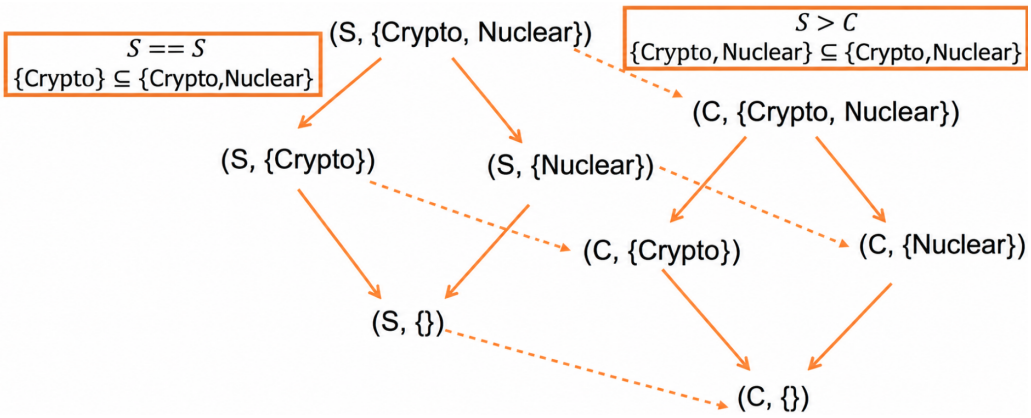
[Hospital] Labels: Admin $<$ Nurse $<$ Surgeon $<$ Doctor. Categories: DEMOGRAPHICS, ANALYSIS, RESULTS. Which statements are true?

1. $(D, \{\}) \succeq (S, \{\})$: **true** ($D \geq S$ and $\{\} \subseteq \{\}$).
2. $(S, \{\}) \succeq (N, \{\text{RESULTS}\})$: **false** ($S \geq N$, but $\{\text{RESULTS}\} \not\subseteq \{\}$).
3. $(S, \{\text{DEM}, \text{RES}\}) \succeq (N, \{\text{DEM}\})$: **true** ($S \geq N$ and $\{\text{DEM}\} \subseteq \{\text{DEM}, \text{RES}\}$).
4. $(D, \{\text{ANA}, \text{RES}\}) \succeq (S, \{\text{DEM}\})$: **false** ($D \geq S$, but DEM is missing).

Which level dominates them all? (Doctor, $\{\text{DEM}, \text{ANA}, \text{RES}\}$): highest label and all categories (the *top*).

Which level dominates only itself? (Admin, $\{\}$): lowest label and no category (the *bottom*). It is dominated by every level.

The dominance lattice



With labels $C < S$ and categories Crypto, Nuclear we obtain $2 \times 2^2 = 8$ security levels, which can be drawn as a lattice (an arrow from x to y means $x \succeq y$: arrows point *down*, from the dominating level to the dominated one; solid arrows keep the label and drop a category, dashed arrows keep the categories and lower the label):

Three key properties.

(a) **Dominance is transitive**: if $x \succeq y$ and $y \succeq z$ then $x \succeq z$ (it is also reflexive and antisymmetric).
(b) There are **top and bottom elements**.
(c) It is **only a partial order**: some pairs are *incomparable*. For instance, neither $(S, \{\text{Crypto}\}) \succeq (S, \{\text{Nuclear}\})$ nor the converse holds; similarly $(S, \{\})$ and $(C, \{\text{Crypto}\})$ are incomparable.

Remark 40.
Incomparability is important for exercises: if neither level dominates the other, then *no* flow is allowed in either direction (neither read nor append/write), because every BLP rule requires a dominance.

3.8.4 Security levels of subjects: clearance

BLP also calls it "classification", but for subjects we speak of **clearance**:

- **Clearance** level(s_i): the **maximum** security level the subject has been assigned.
- **Current security level** current-level(s_i): subjects can **operate at lower security levels** than their clearance.

$$\boxed{\text{level}(s_i) \succeq \text{current-level}(s_i)}$$

Remark 41 (Lowering the current level: what is allowed and what is not)**.**
BLP reasons about **processes (sessions)** and what they have read, not about what a human remembers.

- **Allowed**: a Top Secret general opens a *new session* at current level Unclassified. In that session he can only read Unclassified objects, so the process writing the memo has *never touched* Top Secret data: even a Trojan running in it has nothing secret to leak.
- **Forbidden**: a session that has *already read* a Top Secret object lowers its level and then writes into an Unclassified object. The process holds Top Secret data in memory, so this is exactly the Trojan leak. The *-property forbids it: observing O_1 (TS) and altering O_2 (U) requires level(O_2) $\succeq$ level(O_1), which does not hold. Relabelling the process does not remove the information already in it.

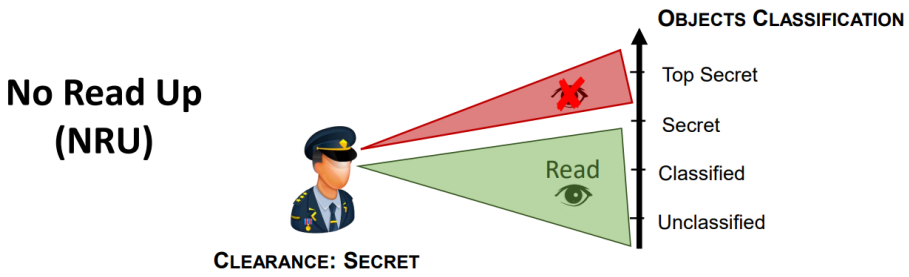
BLP **cannot** prevent the general from typing a secret *from memory* in his Unclassified session: the model controls flows inside the system (processes, files), not people's heads. Cleared humans are *trusted* principals; BLP mainly protects against **software** (Trojans, bugs) acting with the user's authority.
Exam pitfall (Midterm 2024): "the casting director lowers his level to Unclassified and writes the cast list into the cast member's file" is wrong. If it is the same process that read the Confidential cast list, it is a write down (forbidden). If it is a new Unclassified session, it cannot read the cast list, and typing it from memory is not a covert channel but a leak by a trusted human, outside the model.

3.8.5 The simple security property (ss-property): No Read Up

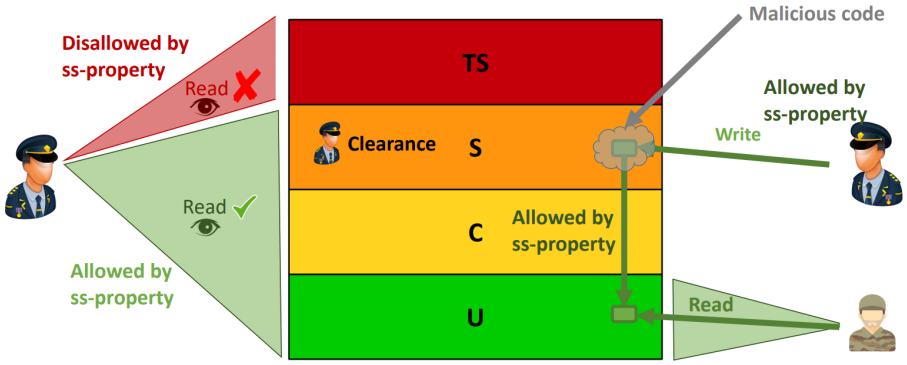
Definition 39 (Simple security property)**.**
If (subject, object, r) is a current access, then

$$\text{level}(\text{subject}) \succeq \text{level}(\text{object}).$$

This is **No Read Up (NRU)**: a subject with clearance Secret can read Unclassified, Classified and Secret objects, but not Top Secret ones.



Why the ss-property is not sufficient



The ss-property only constrains *reading*. Consider a subject with clearance Secret who runs **malicious code** (a Trojan horse):

1. the code reads a Secret object (allowed by the ss-property: Secret dominates Secret);
2. the code writes its content into an Unclassified object (the ss-property says nothing about writing);
3. any Unclassified subject reads the Unclassified object (allowed by the ss-property).

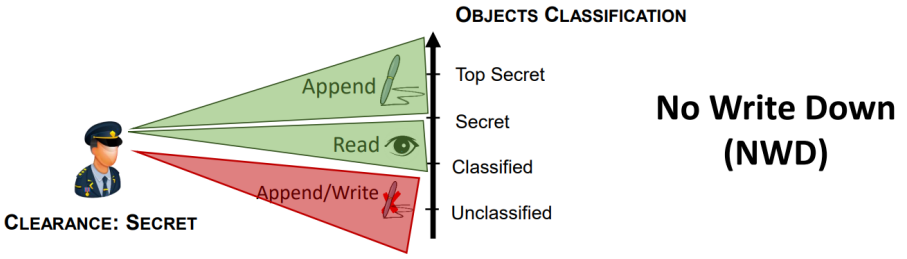
Each individual step is allowed, but Secret information has **flowed down** to Unclassified. The user does not even need to be malicious: the program acts with the subject's authority. We need a rule on writing.

3.8.6 The star property (*-property): No Write Down

Definition 40 (*-property)**.**
If a subject has simultaneous "observe" access (r or w) to O_1 and "alter" access (a or w) to O_2, then

$$\text{level}(O_2) \succeq \text{level}(O_1).$$

In practice, with respect to the current level of the subject, this gives **No Write Down (NWD)**: a subject may only *alter* (append/write) objects whose level dominates its current level.



Remark 42 (Intuition)**.**
Read down, write up. Information can only move from lower to higher levels. A Secret subject can *append* to a Top Secret file ("blind write up": it cannot read the result), which is harmless for confidentiality (but not for integrity, see BIBA!).

3.8.7 The discretionary property (ds-property)

Information should only be accessed on a **need-to-know** basis: being cleared Secret does not mean you need *every* Secret document. **MAC needs DAC** to implement least privilege *inside* a security level. It is also important to protect integrity.

Definition 41 (Discretionary security property)**.**
If an access (subject, object, action) takes place, it **must be in the access control matrix**.

So an access is granted only if *both* the mandatory rules (ss, *) *and* the discretionary matrix allow it.

3.8.8 The Basic Security Theorem

Definition 42 (Basic Security Theorem)**.**
If all state transitions are security preserving, and the initial state is secure, then every subsequent state is secure, regardless of the inputs.

In other words, if for any individual access (1) the ss-property, (2) the *-property and (3) the ds-property are preserved, then security holds for any sequential composition of accesses. A system can be analysed in terms of **single-step state transitions**.

Remark 43.
Is it surprising? **No**: it is essentially an induction over the sequence of states. Its value is methodological (check each transition locally), but it hides the real question: *what are the transitions, and what does it mean to "read" something?*

[One bit leaks through a transition] Assume level(s_1) = TS and level(s_2) = C.

1. s_2 creates o_2, so level(o_2) = C.
2. s_1 reads o_2 (allowed: read down) and then, depending on a Top Secret bit, either
   - changes the object's level: level(o_2) = TS, or
   - leaves it untouched: level(o_2) = C.
3. s_2 attempts to access o_2 at level C: **success or failure leaks 1 bit** of Top Secret information!

Every transition looked "secure", yet information flowed down. The model does not capture the *observable side effects* of transitions (here the success/failure of an access). This is a **covert channel**. (Such attacks motivate the idea that labels should not change while in use, often called *tranquility*.)

3.8.9 Covert channels

Definition 43 (Covert channel)**.**
Any channel that allows **information flows contrary to the security policy**.

The information is hidden inside actions or messages that the policy *allows*. Two families:

- **Storage channels**: the sender modifies a shared stored value that the receiver can observe. E.g. shared counters, ID fields, file metadata (names, sizes, existence of a file, lock state), …
- **Timing channels**: the sender modulates the timing of something the receiver can measure. E.g. use of the CPU, load to memory (cache), queuing time, …

Remark 44 (Link with the principles)**.**
The more resources are shared, the harder it is to eliminate covert channels. This is exactly **Principle 7: least common mechanism**: every shared mechanism (CPU, cache, file system, disk) is a potential communication path between levels.

Mitigation.

- **Isolation**: make communication with the low level impossible (no shared resources).
- **Add noise** to the communication (e.g. random delays), which reduces the bandwidth.

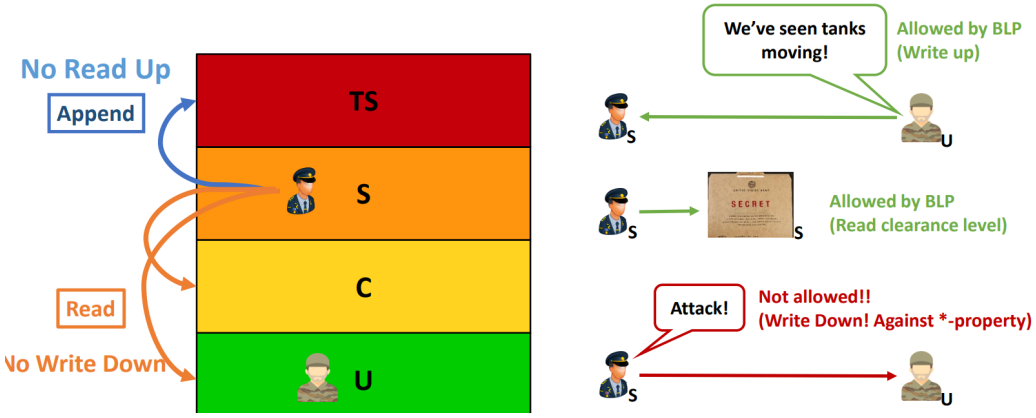
Limits of mitigation:

- It is hard to achieve less than **1 bit/s**.
- That is **OK for documents** (leaking a whole report takes a long time), but **NOT OK for cryptographic keys** (a 128-bit key leaks in about two minutes).
- Hence the DoD policy: **cryptographic keys must always be stored on dedicated hardware**.

Remark 45 (Exam hints on covert channels (Midterm 2024))**.**
When asked to *describe a covert channel*:

- The channel must use **only actions the MAC allows** (read down, append up, shared resources). A channel that requires writing down (e.g. the high subject writing into an Unclassified file) **violates NWD** and is not a covert channel, it is simply forbidden.
- An **external** channel (phone, coffee shop, messaging app) with the message in the clear is **not** a covert channel: the information is not hidden inside an allowed action. (It is outside the system the MAC controls.)
- **Declassification is not a covert channel**: it is run by the policy (not the user), and it removes the sensitive content.
- **Encryption is not a covert channel**: an encrypted message written down is still a write down.

3.8.10 Declassification



[Tanks] An Unclassified observer sees tanks moving and *appends* "We've seen tanks moving!" to a Secret report (write up: allowed by BLP). The Secret commander reads it (read at his clearance level: allowed). He now wants to send "Attack!" to Unclassified soldiers: **this is a write down, not allowed by the *-property**. Yet the system is useless if orders can never reach the soldiers.

Definition 44 (Declassification)**.**
Removing a classification label (or lowering it) from an object.

- It is **very typical and necessary**: information must eventually flow down (orders, public reports, archives).
- It happens **under the control of the security policy**, not at the discretion of a user.
- It **cannot be made inherently safe**: it is a **manual process**, with rules about archives and historical records.
- It is **hard to rule out covert channels**: how do you know the object does not contain secrets (hidden in wording, whitespace, metadata, …)?

Difficulty of declassification in practice

- **Microsoft Word revision history** retains deleted text.
- **PDF redaction** by overlaying graphical elements (usually black rectangles): **the text is still in the file**, and can be copied out.
- **Mosaicing and blurring** are ineffective for redacting text (Hill, Zhou, Saul, Shacham, PETS 2016): the hidden text can be recovered.

Always assume a **strategic adversary** who will look for every trace left.

3.8.11 Limitations of BLP

- **Confidentiality-oriented**: it does not consider integrity or availability (a low subject may append garbage to a Top Secret file).
- **State-based, single-transition model**: too low-level and not expressive.
- The **three security properties are not sufficient** to ensure confidentiality (covert channels, as in the 1-bit example).
- **Changes** in clearance and classification can create covert channels…
- …but a **static system without changes is impractical** (hence the need for declassification).

3.9 Integrity models

3.9.1 Why integrity?

BLP focuses on confidentiality, which is relevant for military and government environments. What about **commercial services**? Banking, stock and sales inventory, stock exchange, land registry, student grades database, electronic contracts, payments, …

- Preventing **fraud** is about protecting **integrity**: the adversary has not influenced the result.
- Confidentiality is either secondary or unnecessary.

Integrity is key for computer security in general!

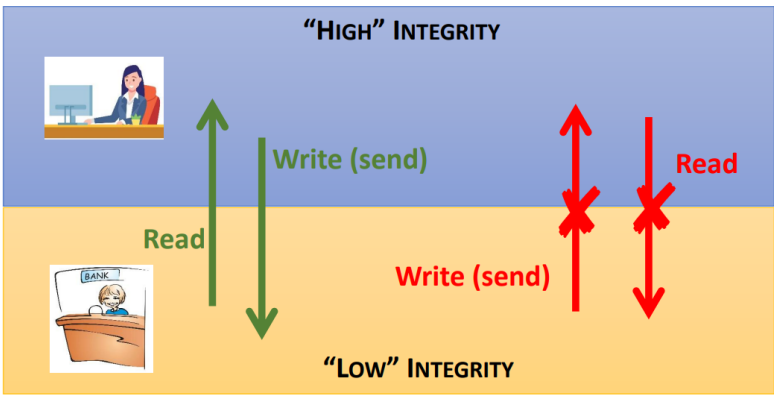
- The **TCB has to have high integrity** (if the reference monitor can be modified, no policy holds).
- **Public key cryptography requires high integrity for confidentiality**: if an adversary can replace Bob's public key with her own, encrypting "to Bob" gives the message to the adversary.

3.9.2 The BIBA model

Subjects and objects have **integrity levels**, from lowest integrity to high integrity. Two operations: **read** (observe) and **write** (modify). Two strict rules:

Definition 45 (BIBA strict integrity rules)**.**

- **Simple integrity property (No Read Down)**: a subject may read an object only if level(object) $\succeq$ level(subject). This **protects higher integrity principals from being corrupted by lower integrity data**.
- ***-integrity property (No Write Up)**: a subject may write an object only if level(subject) $\succeq$ level(object). This **prevents lower integrity principals from corrupting high integrity data**.



BIBA is the **dual of BLP**: **read up, write down**. Information can only flow from high integrity to low integrity.

- **In the bank**: the director (high) can establish a rule and every employee (low) reads it (read up). Employees cannot rewrite the rules (no write up).
- **In the computer**: a web application open in the browser (low integrity, it processes untrusted network input) should not write to the file system (high integrity), at most to `/tmp`.

	BLP (confidentiality)	**BIBA (integrity)**
Read	No Read **Up** (read down)	No Read **Down** (read up)
Write	No Write **Down** (write up)	No Write **Up** (write down)
Information flows	upwards only	downwards only
Protects against	leaking secrets to low levels	corruption of high levels by low data

Table 3.10: BLP and BIBA are duals.

Remark 46.
Using BLP and BIBA together with the *same* levels would forbid everything but same-level access. In practice they use different, independent labels.

3.9.3 BIBA variant 1: low-water-mark for subjects

The strict rules are very rigid. A first relaxation:

- Subjects **start processes at their highest integrity level**.
- When accessing (reading) an object, the subject's current level is **lowered to the lowest of the two**: current-level$(s) \leftarrow \min(\text{current-level}(s), \text{level}(o))$.

So reading down is *allowed*, but it "contaminates" the subject: once it has read low data, it can no longer write high objects.



- It is a **temporary downgrade for the session**.
- Example: **mitigate the impact of a network Trojan**: a process that read network data (low) can no longer write OS data (high).
- Problem: it is **hard to avoid label creep**: subjects keep reading lower data, and after a while everything runs at the lowest level.

3.9.4 BIBA variant 2: low-water-mark for objects

- Once an object has been written to by a subject, it **assumes the lowest level of the object and the subject**.
- Example: a high-integrity database written to by a process with access to the network (low integrity) is labelled "low" integrity.



What is the effect? Writing up is no longer prevented, the object is simply relabelled. This is **dangerous**: it only allows **detection** of integrity violations (after the fact), not prevention. Mitigation: **replicate objects** (keep a high-integrity copy) and **sanitize or erase** the contaminated ones.

3.9.5 BIBA additional action: invoke

Subjects can also *invoke* (call) other subjects:

- **Simple invocation**: only allow subjects to invoke subjects **with a label they dominate** (invoke lower or equal).
  - \+ Protects high integrity data from misuse by low integrity principals (a low subject cannot drive a high subject).
  - − What level is the output? (the result comes from a lower-integrity subject)
- **Controlled invocation**: only allow subjects to invoke subjects **that dominate them** (invoke higher, e.g. through a well-defined interface such as a system call).
  - \+ Prevents corruption of high integrity data: the high subject does the modification itself.
  - − Hard to detect polluting information passed in by the low invoker (this is exactly the sanitization problem below).

3.9.6 Sanitization

Definition 46 (Sanitization)**.**
The process of taking objects with "**low**" integrity and "**lifting them**" to "**high**" integrity.

It is the integrity counterpart of declassification. "Sanitization" problems are **the root cause of large classes of real-world security vulnerabilities**: malformed "low" (user) input influences "high" (service) data and code.

- **Web security**: the web server (high) accepts input from the web client (low), passes it to an SQL interpreter → **SQL injection** vulnerability.
- **OS security**: a UNIX **suid** program (high) accepts input from a user (low) into a short buffer → **buffer overflow**.

Fundamental principle of sanitization

Positively verify that "low" objects are within a **valid set** before elevating their integrity to "high".

- **Whitelist**: check that all properties of good objects hold.
- **Do not blacklist**: do not just check for bad objects or properties.

This is **Principle 2: fail-safe defaults**, "base access decisions on permission rather than exclusion" (Saltzer & Schroeder, 1975).

The universe of good things is small and well-defined; the set of bad things is large and undefined. Asking "is it in the universe of good things? accept" is sound; asking "is it in the set of bad things? reject" always misses something (and covert channels are difficult to catch anyway).

3.9.7 Principles to support integrity

Three principles to guide design choices:

- **Separation of duties**: require **multiple principals** to perform an operation. It is harder for an adversary to tamper with the system, as they have to corrupt two principals.
- **Rotation of duties**: allow a principal only a **limited time** in any particular role, and limit other actions while in this role. It is harder for an adversarial insider to tamper with the system (no time to set up a long-running fraud, and the successor may notice it).
- **Secure logging**: a **tamper-evident log** to recover from integrity failures. **Consistency of the log across multiple entities** is key. It is harder to make an integrity breach durable.

Remark 47 (Integrity bootstraps other properties)**.**
To *bootstrap* means to build one property on top of another: **high integrity can be used to obtain high confidentiality or high availability**, and losing integrity can make you lose them too.

- **Integrity ⇒ confidentiality (PKI).** Alice encrypts a message for Bob with Bob's public key. If an adversary can *replace* Bob's key in the directory with her own, Alice in fact encrypts for the adversary, who decrypts it, reads it, and re-encrypts it with Bob's real key so that nobody notices. The encryption is perfect, yet confidentiality is lost because the *integrity of the key* was not guaranteed. A PKI (certificates signed by an authority) guarantees that "this key belongs to Bob"; confidentiality then follows.
- **Integrity ⇒ availability (replication).** To keep a service available, data is replicated on several servers: if one fails, another takes over. But a *corrupted* replica may serve wrong data, or spread the corruption to the others during synchronization. If the integrity of each replica can be *verified* (hashes, signatures), the bad copy is detected and a good one is used instead. Replication only gives availability if we know which replicas are sound.
- **Conversely**, a loss of integrity leads to **low confidentiality** or **low availability**

This is why integrity is central in computer security: the **TCB itself must have high integrity**, otherwise no other property holds.

3.10 The Chinese Wall model

D. F. C. Brewer and M. J. Nash, *The Chinese Wall Security Policy*, IEEE S&P 1989.

3.10.1 Motivation

Inspiration: UK rules about handling **conflicts of interest** in the financial sector.

- A separation must exist **at all times**, even within the same firm, between people engaging in activities that conflict with each other (e.g. a consultant advising two competing companies).
- Cost of failure: large fines and reputation.

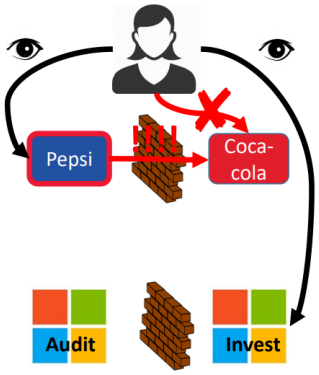
3.10.2 Entities and basic concepts

1. All objects are associated with a **label denoting their origin**: "Pepsi Ltd.", "Coca-Cola Co.", "Microsoft Audit", "Microsoft Investments".
2. The originators define **conflict sets** of labels: {Pepsi Ltd., Coca-Cola Co.}, {Microsoft Audit, Microsoft Investments}.
3. Subjects are associated with a **history of their accesses** to objects, and in particular of their labels.

Remark 48.
Unlike BLP and BIBA, the Chinese Wall is **dynamic**: what a subject may access depends on what it has accessed *before*. Initially, a subject may access anything; each access builds the wall.

3.10.3 Access rule

Definition 47 (Chinese Wall access rule)**.**
A subject can access an object (for either read or write) if the access **does not allow an information flow between items with labels in the same conflict set**.



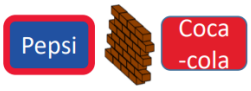
[Direct flow] Alice starts her first day at work.

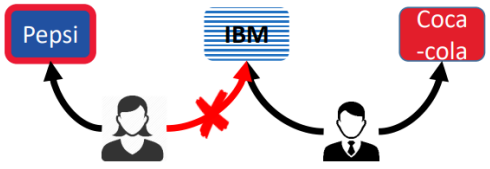
1. She accesses files of "Pepsi Ltd.": OK (empty history).
2. She accesses files of "Microsoft Investments": OK (different conflict set).
3. She tries to access files of "Coca-Cola Co.": **access denied**!

Why? She has already accessed files of "Pepsi Ltd.", so an information flow between Pepsi and Coca-Cola, in the same conflict set, might happen (she could work again with Pepsi). Similarly, she can no longer access "Microsoft Audit".

3.10.4 Indirect flows

Direct flows within a conflict set are easy to detect. What about indirect ones?





[Indirect flow] Alice and Bob start together.

1. Alice is assigned to "Pepsi Ltd.": OK.
2. Bob is assigned to "Coca-Cola Co." and "IBM Co.": OK (IBM is not in conflict with Coca-Cola).
3. Alice tries to access files of "IBM Co.": **access denied**!

Why? If she writes into IBM files with her knowledge of Pepsi, Bob can read them, and the information may flow to Coca-Cola. Information flows **transitively** through objects shared by different subjects, so the model must track flows, not only direct accesses.

Sanitization is necessary for business. If every shared object blocks everyone, nobody can work. Some items are therefore "**un-labelled**" as long as the information **cannot lead to any conflict of interest**, e.g. extracting some "general market information". Sanitized objects can be accessed by anybody without building a wall.

3.10.5 Multilateral security

BLP and BIBA are *multilevel*: flows are vertical between ordered levels. The Chinese Wall is an example of **multilateral security**: the constraints are *between* parties at the same level (lateral), whose interests and security properties conflict with each other. It protects both confidentiality (Pepsi's secrets do not reach Coca-Cola) and integrity (advice to Coca-Cola is not influenced by Pepsi's interests).

3.11 Summary

- **MAC**: a central policy decides, and it must hold even against subjects trying to subvert it. **Security models** are design patterns for MAC policies; the devil is in the details (subjects, objects, mechanisms).
- **Security level** = (classification, {categories}). $(l_1, c_1) \succeq (l_2, c_2)$ iff $l_1 \geq l_2$ and $c_2 \subseteq c_1$. Dominance is a transitive **partial order** forming a lattice with top and bottom; some levels are incomparable.
- Subjects have a **clearance** (maximum level) and a **current level** it dominates.
- **BLP** (confidentiality): **ss-property** (No Read Up), ***-property** (No Write Down; observe O_1 and alter O_2 requires level(O_2) $\succeq$ level(O_1)), **ds-property** (access must be in the matrix: need-to-know, MAC needs DAC). Read ⇒ down, append ⇒ up, write ⇒ same level.
- **Basic Security Theorem**: secure initial state + secure transitions ⇒ every state is secure. Not sufficient in practice: **covert channels** (storage, timing) leak information through allowed actions; more sharing means more channels (least common mechanism). Mitigation: isolation, noise; < 1 bit/s is hard, so keys go on dedicated hardware.
- **Declassification**: necessary, under the control of the policy, manual, never inherently safe (Word history, PDF black boxes, blurring).
- BLP limitations: only confidentiality, too low-level, properties insufficient, changes create covert channels, static systems impractical.
- **BIBA** (integrity, the dual of BLP): **No Read Down**, **No Write Up**. Variants: low-water-mark for subjects (label creep), for objects (only detection; replicate and sanitize). Invocation: simple vs. controlled.
- **Sanitization**: lifting low-integrity objects to high integrity; root cause of SQL injection, buffer overflows, XSS. Use **whitelists, not blacklists** (fail-safe defaults).
- Integrity principles: **separation of duties**, **rotation of duties**, **secure logging**. Integrity can bootstrap confidentiality (PKI) and availability (replication).
- **Chinese Wall**: origin labels, conflict sets, access history; deny any access allowing a flow between labels of the same conflict set, including **indirect flows**. Sanitized "general" information is un-labelled. An example of **multilateral security**.

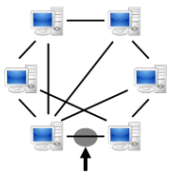
Chapter 4
Applied Cryptography

4.1 Introduction

4.1.1 Why does cryptography matter?

Cryptography protects data in two situations:

- **Data in transit**: securing communication (e.g. HTTPS, VPNs).
- **Data at rest**: securing stored information (e.g. encrypted backups, encrypted disks).



Data in transit



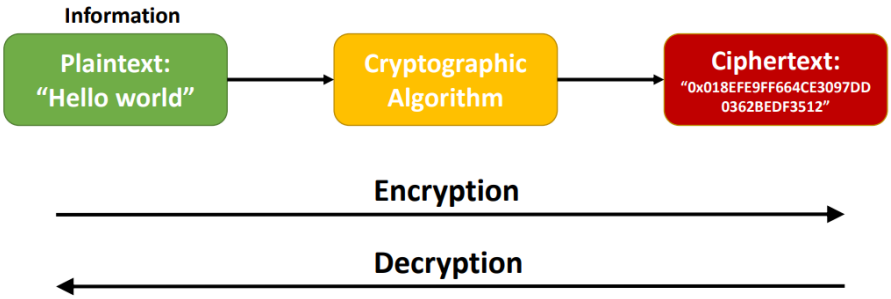
Data at rest

Cryptography is historically born from the quest for **confidentiality** (information cannot be accessed by unauthorized parties), but it is also the building block for many other properties:

- **Integrity**: ensuring data has not been tampered with (hashing, MACs, signatures);
- **Authentication**: verifying identity (protocols);
- but also **anonymity**, non-repudiation, etc.

This first lecture focuses on the basics of using cryptography for **confidentiality**. Integrity and authentication come in the following lectures.

4.1.2 The core problem: secure communication over an insecure channel



We need a way for **Alice** to send a message to **Bob** such that **Eve** (the adversary, the *eavesdropper*) **cannot read it**, even though Eve sees everything that goes over the channel.

Remark 49.
Confidentiality of **data at rest** is a particular case where **Alice** = **Bob**: Alice "sends" a message to her future self (the disk, the backup), and Eve is whoever gets access to the storage.

4.1.3 Encryption and decryption

Definition 48 (Encryption / decryption algorithm)**.**

- The **encryption algorithm** is a set of cryptographic instructions that converts a **plaintext** message into a **ciphertext**.
- The **decryption algorithm** is a set of cryptographic instructions that converts a **ciphertext** back into the **plaintext**.

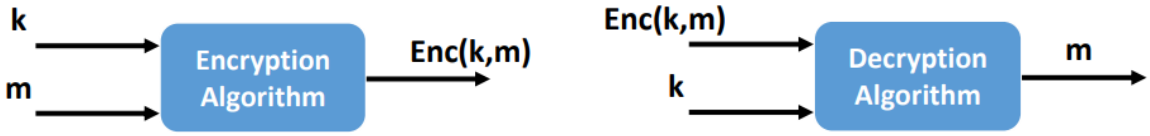
Both algorithms require a **key**: encryption **cannot be reversed without the key**.

Notation (cryptography as functions):

- **Plaintext** M: the original message (e.g. "Hello world");
- **Key** K: a secret value;
- **Ciphertext** C: the scrambled message (e.g. `0x018EFE9FF664CE3097DD…`).

$$\boxed{C = E_K(M) \qquad \text{and} \qquad M = D_K(C)}$$

We also write $\mathrm{Enc}(k, m)$ and $\mathrm{Dec}(k, c)$.



Protocol for confidentiality.

1. Get a key k **shared** between Alice and Bob.
2. Alice encrypts the message: $m \mapsto \mathrm{Enc}(k, m)$.
3. Alice sends $\mathrm{Enc}(k, m)$ over the insecure channel.
4. Bob decrypts: $\mathrm{Dec}(k, \mathrm{Enc}(k, m)) = m$.

Step 1 is far from trivial: it is the **key distribution problem**, solved in Section 4.6 with public-key cryptography.

4.1.4 The core requirements

Definition 49 (Correctness: invertibility)**.**
The decryption function D_K must be the inverse of E_K:

$$\forall K, \forall M, \quad D_K(E_K(M)) = M.$$

Otherwise, Bob cannot recover the original message M.

Definition 50 (Security requirement)**.**
To provide security, E_K must also be **hard to invert without knowing the key** K.

Hard to invert: the key space. Concretely, in an **ideal** cryptosystem, the only viable attack for Eve to find the plaintext M must be to **try every single possible key** K: a **brute-force attack**. The goal of a secure scheme is to **force the attacker into this situation**. The **key space** (the set of all possible keys) must then be large enough to make brute force infeasible.

Remark 50 (Eve knows the algorithm)**.**
In all the examples below, Eve knows *which* cipher is used (Caesar, substitution, OTP, …); only the **key** is secret. This is the **open design** principle seen in the security principles lecture (also known in cryptography as *Kerckhoffs' principle*): the security must rest on the secrecy of the key, never on the secrecy of the design.

4.1.5 Bits of security

Definition 51 (Bits of security)**.**
A scheme provides N **bits of security** if the best known attack requires about 2^N operations (attempts). For an ideal scheme where brute force is the best attack, the bits of security equal $\log_2 |\mathcal{K}|$, where $|\mathcal{K}|$ is the size of the key space.

- **Goal**: an N-bit key should offer security **as close to** N **bits as possible**, i.e. require 2^N attempts.
- **The break**: if a 1024-bit key can be broken with only 2^{40} attempts (40 bits of security), the algorithm is **considered broken**, even if 2^{40} were still a lot of work.

Remark 51.
Key space size $\neq$ security. A huge key space is *necessary* (otherwise brute force works) but *not sufficient*: a structural weakness can let the attacker skip almost all the keys. The two classical ciphers below illustrate exactly this.

4.2 Bad cryptography: classical ciphers

These are examples of **bad** cryptography. They are pedagogically interesting because they introduce the first attack: **frequency analysis**.

4.2.1 Caesar's cipher

Definition 52 (Caesar's cipher)**.**

- **Encryption**: shift each letter by a fixed number K in the alphabet: $E_K(x) = (x+K) \bmod 26$.
- **Decryption**: shift each letter by $-K$: $D_K(y) = (y-K) \bmod 26$.
- **Key space**: only 25 possible (non-trivial) keys.

With $K = 3$:

$$\texttt{ATTACK AT DAWN} \xrightarrow{K=3} \texttt{DWWDFN DW GDZQ}$$

(A→D, T→W, C→F, K→N, W→Z, N→Q.)

Security insight. $\log_2 25 \approx$ **4.6 bits of security**: far too small for real-world use. Brute force (trying the 25 keys and reading which output is English) is already trivial. But there is an even better attack.

Cryptanalysis: frequency analysis

- Eve knows that Alice wrote a **long-enough message** for Bob **in English**.
- She knows that the most frequent letter in English is '`e`'.
- She identifies the **most frequent letter in the ciphertext**: it likely corresponds to '`e`'.
- She directly recovers the key: $K =$ (most frequent ciphertext letter) $-$ `e` (mod 26).

This is a **frequency analysis attack**: the 25 keys are reduced to **one** likely candidate, without any brute force.

4.2.2 The substitution cipher

Maybe the problem was having only 25 keys? Let us use many more.

Definition 53 (Substitution cipher)**.**
Each letter is mapped to a unique, different letter, defined by a **permutation of the 26 letters**. The key is the permutation. Decryption applies the inverse permutation.

Plain alphabet:	`ABCDEFGHIJKLMNOPQRSTUVWXYZ`
Key (permuted):	`HOWBUGIACRYEVZXPJQMSNTFDKL`

`hello world` $\longrightarrow$ `aueex fxqeb`

(h→a, e→u, l→e, o→x, w→f, r→q, d→b.)

From 25 keys to $\approx 4 \times 10^{26}$ **keys.**

- Number of keys: $26! \approx 4.03 \times 10^{26}$ ($\approx$ 403 septillion).
- Bit security: $\log_2 26! \approx$ **88.4 bits**?
- This key space *looks* big enough (brute force is infeasible), but the cipher is **still easily broken by the same frequency analysis**.

Cryptanalysis: the flaw, again

- **Vulnerability**: the cipher **preserves the statistical properties of the plaintext language** (single-letter frequencies, but also frequent pairs like "th", frequent words like "the", double letters, …).
- If Eve has a long enough ciphertext C, statistical analysis breaks the cipher, rendering the full 26! key space irrelevant.

Remark 52 (The goal of the adversary may be smaller)**.**
The adversary does not necessarily want the **full key**:

- she might only recover **part of the key** (the mapping of a subset of letters), which may be enough to read most of the text;
- sometimes her goal is even smaller: she only wants to know whether Alice sent "`Yes`" or "`No`" to Bob. With Caesar or substitution, the **length** and **letter pattern** of the ciphertext already tell her.

A secure scheme must prevent *any* information leak about the plaintext, not only the full recovery of the key.

Cipher	Key space	Nominal security	Effective security
Caesar	25	≈ 4.6 bits	≈ 0 bits (1 guess by frequency analysis)
Substitution	$26! \approx 4 \times 10^{26}$	≈ 88.4 bits	a few tries (frequency analysis + dictionary)

Table 4.1: Bits of security versus key space size for the classical ciphers.

4.3 Adversaries in cryptography

As always in computer security, the security of a scheme is **always measured relative to the power of the adversary** (the threat model). The general principle of the course still applies: security is studied against a **strategic adversary** that is given **limited, well-defined resources**. Here are the typical threat models in cryptography.

4.3.1 Passive eavesdropping (ciphertext-only)

In the Caesar and substitution examples, Eve's capabilities were very limited:

- she **observed a long-enough ciphertext** C corresponding to the encryption of a piece of English;
- and she had some compute power to test a few keys.

This is a **passive eavesdropper**: Eve can **only read the ciphertext** (in the literature, a *ciphertext-only attack*). This is not the only possible adversary model.

4.3.2 Active adversaries

A **more active attacker** can somehow **influence the system**: convince Alice to send Bob very specific messages, look at Bob's screen for two minutes to see some decrypted messages, observe the precise time it takes Bob to run his algorithm, …: anything that goes beyond just observing the communication.

Active Model 1: Known Plaintext Attack (KPA)

Definition 54 (Known Plaintext Attack)**.**
Eve is given access to **multiple pairs** (M, C) of messages and their corresponding ciphertexts, all encrypted with the secret key K. From these pairs, she tries to find the key K (or to decrypt *other* messages encrypted under K). Eve does **not choose** which pairs she sees.

Why is KPA realistic? Encryption is very often applied to **structured data**:

- **Standard headers**: many encrypted messages contain predictable headers ("`From:`", a destination address in a packet, timestamps, file format headers, …);
- **Malicious Guessing**: if Eve guesses a message (or part of it) and observes its encryption, she obtains an (M, C) pair.

KPA and the substitution cipher. Under KPA, the substitution cipher becomes even more broken. If Eve knows that $M =$ `THE QUICK BROWN FOX`, she **immediately recovers the mapping of many letters**, drastically reducing the effective key space, **without even doing a statistical analysis**. When Alice later reuses K, a significant part of the key has already leaked; with a dictionary, Eve recovers the rest in very few tries.

Active Model 2: Chosen Plaintext Attack (CPA)

Definition 55 (Chosen Plaintext Attack)**.**
Eve can somehow convince Alice (or the system) to encrypt **arbitrary messages chosen by Eve** with the secret key. More abstractly: for any chosen plaintext m, Eve gets $E_K(m)$. We say that Eve has access to an **encryption oracle**.

Remark 53.
In KPA, Eve does not get to choose which (M, C) pairs she observes; in CPA she *chooses* m and gets $(m, E_K(m))$. CPA is therefore a **strictly stronger** adversary model than KPA (and KPA is stronger than ciphertext-only). A scheme secure under CPA is secure under KPA, not the converse.

Why is CPA realistic?

- **Messaging app**: a secure messaging service (Signal, WhatsApp) encrypts messages with the sender's key. If Eve gets access to Alice's phone for a few minutes, she can send any data she chooses to Bob and observe the encryption: an (M, C) pair of her choice.
- **Encryption API**: Eve may interact with an API endpoint where she provides data and receives the encrypted output.

CPA and the substitution cipher: complete break. Eve chooses the plaintext

$$M = \texttt{abcdefghijklmnopqrstuvwxyz}.$$

The resulting ciphertext C **is the entire key** (the full permutation), in **a single query**!

Practical Threat Model Side-channel attacks

Definition 56 (Side-channel attack)**.**
Eve is allowed not only to access an ideal oracle, but also to **measure physical characteristics of the actual implementation** while it is encrypting/decrypting:

- **Timing attack**: Eve measures how long it takes for a given message to be encrypted or a ciphertext to be decrypted;
- **Power analysis**: Eve observes the energy consumed by the device (e.g. a credit card) while doing the crypto.

Why are side channels realistic?

- **Malicious ownership**: you often *own* a device (a phone, a smart card, an embedded chip) that holds keys belonging to *another* principal (Google, your bank), which are meant to be unreadable to you. The adversary has physical access by design.
- **Example (DRM)**: the decryption key for Digital Rights Management content (a movie, a song) is embedded in your media player or console. By measuring power or timing, an attacker could extract that secret key.

Remark 54.
Side channels attack the *implementation*, not the mathematics: a cipher that is perfectly secure on paper can leak its key through timing or power consumption. Compare with the **timing covert channels** of the MAC lecture: the leak is in an observable side effect, not in the intended output.

4.4 Perfect secrecy and the One-Time Pad

4.4.1 Removing frequency analysis

Frequency analysis works because the same plaintext letter is always encrypted to the same ciphertext letter. To remove it, we must make sure that **letters are not encrypted to the same values**. One way to do this: use a **random key as long as the message**, so that every part of the message is encrypted with a different piece of key. This long key is called a **one-time pad**.

Recall: XOR. The bitwise exclusive or $\oplus$ satisfies:

$$a \oplus 0 = a, \qquad a \oplus a = 0, \qquad a \oplus b = b \oplus a, \qquad (a \oplus b) \oplus c = a \oplus (b \oplus c),$$

and therefore $\boxed{a \oplus b \oplus b = a}$.

Definition 57 (One-Time Pad (OTP))**.**

- **Key**: a string k of **truly random** bits, **as long as the message**, **pre-shared** between Alice and Bob, and **used only once**.
- **Encryption**: translate the message into bits and XOR it with the key:

$$\mathrm{Enc}(k, m) = m \oplus k.$$

- **Decryption**: XOR the ciphertext with the same key:

$$\mathrm{Dec}(k, c) = c \oplus k = m \oplus k \oplus k = m.$$

[Encrypting "YEAH"] YEAH in ASCII is `0x59454148`.

Message (YEAH)	`01011001 01000101 01000001 01001000`
OTP key k	`01110101 00011101 01001010 01001010`
$c = m \oplus k$	`00101100 01011000 00001011 00000010`
$c \oplus k$	`01011001 01000101 01000001 01001000` = YEAH

Decryption gives back exactly the same bits as the message.

4.4.2 Why is the OTP perfectly secure?

Intuition: for any ciphertext C, **every possible plaintext M (of the same length) is equally consistent**. Since the key is uniformly random, C gives the adversary **zero new information** about M.

[Any plaintext fits any ciphertext] The ciphertext $c =$ `00101100 01011000 00001011 00000010` above came from YEAH. But it could just as well be the encryption of NOPE (`0x4e4f5045`) under the key

$$k' = \text{NOPE} \oplus c = \texttt{01100010 00010111 01011011 01000111}.$$

Since all keys are equally likely, Eve has no way to tell whether Alice said "YEAH" or "NOPE". For every pair (m, c) there is **exactly one** key $k = m \oplus c$ mapping m to c.

Definition 58 (Perfect secrecy)**.**
An encryption scheme is **perfectly secret** if observing the ciphertext does not change the adversary's knowledge about the plaintext:

$$\forall m, \forall c, \qquad P\big(M = m \mid E_K(M) = c\big) = P(M = m).$$

Here, the plaintexts m follow some distribution $P(M = m)$ (e.g. "Yes" is more probable than "Autobus"), and we assume that the key K is **uniformly distributed** over $\{0,1\}^n$ and independent of M.

Proof that the OTP is perfectly secret. Let n be the message length. By the definition of conditional probability,

$$P(M = m \mid E_K(M) = c) = \frac{P(M = m \cap E_K(M) = c)}{P(E_K(M) = c)}.$$

Numerator. $E_K(m) = m \oplus K = c \iff K = m \oplus c$. So, using the independence of M and K,

$$P(M = m \cap M \oplus K = c) = P(M = m \cap K = m \oplus c) = P(M = m) \cdot P(K = m \oplus c).$$

Denominator.,

$$P(E_K(M) = c) = P(K = m \oplus c).$$

Hence

$$P(M = m \mid E_K(M) = c) = P(M = m). \qquad \square$$

Remark 55.
Perfect secrecy is an **information-theoretic** guarantee: it holds even against an adversary with **unlimited computing power**. Brute force is useless: trying all keys produces *all* possible plaintexts, each equally plausible. This is the strongest possible form of confidentiality, and it costs a key as long as the message.

4.4.3 The key problem of the OTP

The OTP requires keys that are **truly random**, **message-length**, and **used only once**.

The showstopper. Securely pre-distributing message-length keys for real-world applications is **impractical**: to send 1 GB of data, Alice and Bob must first exchange 1 GB of secret key over a secure channel. One might then think: if it is hard to exchange keys, can I just reuse them? **No.**

4.4.4 Key reuse: the "two-time pad"

One-time pads are called like this because they **must not be reused**. Suppose Alice encrypts two messages M_1, M_2 with the same key K:

$$C_1 = M_1 \oplus K, \qquad C_2 = M_2 \oplus K.$$

Eve XORs the two ciphertexts and **the key cancels out**:

$$\boxed{C_1 \oplus C_2 = M_1 \oplus K \oplus M_2 \oplus K = M_1 \oplus M_2.}$$

Eve cannot directly read M_1 or M_2, but she learns **their XOR**, which is information about the plaintexts. This information feeds frequency analysis and helps recover the messages themselves.

[Exercise from the lecture: key reuse on two 5-letter words] Alice reuses K to encrypt two single-word English messages of length 5, M_1 and M_2, producing $C_1 = M_1 \oplus K$ and $C_2 = M_2 \oplus K$. **Show that Eve can "likely" recover the key and the two messages.**

Solution.

1. Eve computes $C_1 \oplus C_2 = M_1 \oplus M_2$ (the key cancels).
2. She takes an **English dictionary of all 5-letter words** (a few thousand words W).
3. For every pair (W_1, W_2) of dictionary words, she checks whether $W_1 \oplus W_2 = C_1 \oplus C_2$. This is a few million cheap XORs.
4. Since $M_1 \oplus M_2$ is 40 bits and real words are very constrained, **very few pairs** (likely only the right one, and its swap) match.
5. She then recovers the key $K = C_1 \oplus M_1$, and can decrypt anything else encrypted with K.

The word "likely" is because several pairs could in principle match; in practice the candidate set is tiny.

4.4.5 The OTP does not provide integrity

The OTP guarantees **confidentiality** (nobody can read it). It does **NOT** guarantee **integrity** (nobody can tamper with it).

Bit-flipping attack. Let Δ be any bit string (e.g. $\Delta = 100\ldots0$ to flip the first bit).

1. Eve intercepts C and sends $C' = C \oplus \Delta$ to Bob.
2. Bob decrypts:
$$M' = C' \oplus K = M \oplus K \oplus \Delta \oplus K = M \oplus \Delta.$$

Result: Eve successfully changed the message (M' is M with the bits of Δ flipped) **without knowing** K. We say the OTP is **malleable**.

Remark 56 (Exam hints: confidentiality $\neq$ integrity)**.**

- Encryption alone **never** gives integrity. To detect tampering, one needs a separate mechanism (a **MAC** with a secret key, or a digital signature; next lectures). In a past MCQ, the correct way for Roberta to send m with confidentiality *and* integrity, with two pre-shared keys, was $\text{Enc}(K_1, m), \text{MAC}(K_2, \text{Enc}(K_1, m))$: two *different* keys, and the MAC computed over the ciphertext.
- **XOR with a known value hides nothing.** $x \oplus y$ protects x only if y is secret, uniformly random and used once. In the Final 2024, an IV computed as $k \oplus \text{pad(time)}$ instead of a hash was a vulnerability: the IV is not secret and the time is public, so anyone recovers $k = \text{IV} \oplus \text{pad(time)}$.

4.5 From the OTP to stream ciphers

4.5.1 Symmetric cryptography

In **symmetric** schemes, encryption of the plaintext and decryption of the ciphertext are done using **the same key**. Two main types:

- **Block ciphers**: operate on fixed-size blocks (e.g. 128 bits). Example: **AES** (Advanced Encryption Standard).
- **Stream ciphers**: operate one bit/byte at a time, like a **pseudo-OTP**. Example: **ChaCha20**.

This lecture dives deeper into stream ciphers.

Definition 59 (Symmetric cryptographic key)**.**
A **fixed-size input** to symmetric cryptographic primitives. The **size of the key** influences the level of security provided. Its properties:

- **Known to both parties**: the partners must agree on the key before starting to use the primitive.

- **Reused**: the key is pre-shared once and then reused (but keys do have a "duration": they are renewed after some time).
- **Secret**: revealing the key eliminates any protection provided by the primitive.

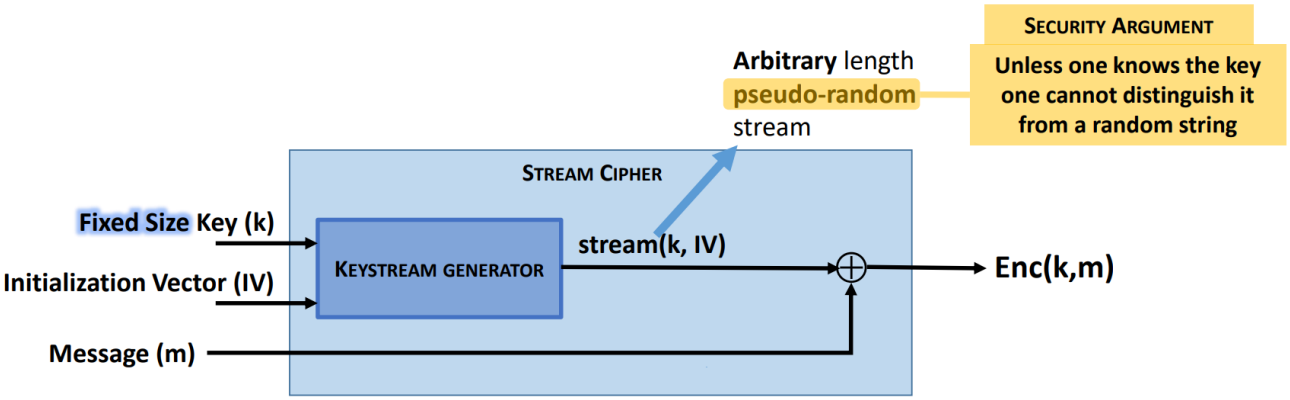
Remark 57.
Note the contrast with the OTP: a symmetric key is **short and reused**, whereas the OTP key is as long as the message and used once. The whole point of stream ciphers is to get (almost) OTP security from a short reusable key.

4.5.2 Stream ciphers: the pseudo-OTP

A stream cipher attempts to **emulate the OTP's security while solving the key-length problem**.

Definition 60 (Stream cipher)**.**

1. **Short key** K: Alice and Bob share a small, manageable key (much smaller than the message), which must be kept **secret**.
2. **Keystream generator (KSG)**: takes K and an **Initialization Vector (IV)** and produces an arbitrarily long, **pseudo-random** bit stream $S = \text{stream}(K, \text{IV})$.
3. **Encryption**: $C = M \oplus S$, as with the OTP.
4. **Decryption**: the receiver feeds the KSG with the shared key and the IV (the IV is **sent along with the ciphertext**, in the clear), recreates the same stream S, and computes $M = C \oplus S$.



Security argument. The output stream is **pseudo-random**: **unless one knows the key, one cannot distinguish it from a truly random string**. We generate potentially infinitely long "randomness" S from a finite secret K, so the security depends entirely on S being **computationally indistinguishable** from a truly random OTP key.

Remark 58 (Perfect vs. computational security)**.**
A stream cipher is **not** perfectly secret: the key is shorter than the message, so an unbounded adversary could try all $2^{|K|}$ keys and see which one gives a sensible plaintext. Its security is **computational**: breaking it should take about $2^{|K|}$ operations, which is infeasible for e.g. $|K| = 128$ or 256.

Why does the KSG also take an IV?

The key is **reused** across messages. Without an IV, the KSG would produce the **same stream S for every message**, which is exactly a **reused one-time pad**: one could XOR two ciphertexts to get $C_1 \oplus C_2 = M_1 \oplus M_2$, recover the prefix of S from any known plaintext ($S = C \oplus M$), and decode future messages. The IV makes sure that **two different messages are encrypted with two different streams**.

- The IV does **not need to be secret** (it is sent in the clear with the ciphertext).
- It must **not be repeated** with the same key (otherwise the stream repeats and we are back to key reuse).

Strengths and weaknesses

Weaknesses	
Low diffusion	A change in one plaintext bit only affects **one** ciphertext bit.
Susceptibility to modification	Low diffusion makes it easy to **tamper** with the message (bit flipping, exactly like the OTP).
Strengths	
Speed	Algorithms are **linear in time** and **constant in space**.
Low error propagation	An error in one bit (e.g. noise on the channel) does not affect the subsequent symbols.

Table 4.2: Stream ciphers: strengths and weaknesses.

Cryptanalysis: periodicity

- A keystream generator with a **finite state** (say L bits) is **eventually periodic**: it has at most 2^L states, so after at most 2^L steps it revisits a state and from then on repeats.
- If the message is longer than the period, the stream repeats: two parts of the message are encrypted with the same stream, i.e. key reuse.
- **The attack**: if the period is identified and too small, knowing one period of the keystream (e.g. from a known plaintext) gives the keystream for the **entire message**.

4.5.3 Interlude: building keystream generators

Remark 59.
You are **not expected to fully understand** this interlude: it illustrates design patterns for KSGs, the challenges of building secure ones, and the math needed to study them.

Linear Feedback Shift Registers (LFSR)

Definition 61 (LFSR)**.**
A **linear recurrence relation**: the next output bit is a **linear function (XOR)** of previous bits. It extends an initial random sequence of bits (the state) into an arbitrarily long sequence of (maybe?) random-looking bits.

Initial state of 4 bits $a_0, \ldots, a_3$ and recurrence $a_n = a_{n-3} \oplus a_{n-4}$. Starting from $1, 0, 0, 0$:

$$a_4 = a_1 \oplus a_0 = 1, \quad a_5 = a_2 \oplus a_1 = 0, \quad a_6 = a_3 \oplus a_2 = 0, \quad a_7 = a_4 \oplus a_3 = 1, \quad a_8 = a_5 \oplus a_4 = 1, \ldots$$

Output sequence: $1, 0, 0, 0, 1, 0, 0, 1, 1, \ldots$

Advantage: it uses only shift registers (state storage) and XOR gates (feedback), so it is **extremely fast and efficient in hardware**.

Randomness of LFSRs.

- **Maximal period**: if the characteristic polynomial (AICC1) of the recurrence is **primitive**, an L-bit register goes through the maximum possible number of states before repeating: $\mathbf{2^L - 1}$ (all states except the all-zero state, which is a fixed point: $0 \oplus 0 = 0$).
- **Distribution**: every non-zero state appears exactly once per cycle, so the output is highly **balanced**: over one cycle it contains exactly 2^{L-1} ones and $2^{L-1} - 1$ zeros.

Math danger. Despite passing some statistical tests, an LFSR is **purely linear**. Algorithms like **Berlekamp–Massey** (beyond the scope of the class) recover the entire LFSR state, hence the whole keystream, from **a short segment of output** (about $2L$ bits, easily obtained with a known plaintext). **LFSRs must not be used directly as keystream generators**, though they have traditionally been used as *building blocks* of KSGs.

A5/1: a broken stream cipher

- Used historically to secure **GSM** mobile phone communications.
- Built by **combining multiple LFSRs in a non-linear way**, to overcome the linearity flaw while staying cheap and keeping the nice statistical properties.
- **The break**: despite the added complexity, mathematical weaknesses were found, allowing the cipher to be broken **much faster than brute force**.

Non-broken stream ciphers

There are modern stream ciphers for which there is **no known practical cryptanalysis**:

- **Trivium**: based on three NLFSRs (non-linear variants of LFSRs) glued together with XOR and AND gates in a complex way;
- **Salsa20** (and its variant ChaCha20): using different techniques.

4.5.4 Bit security and consequences: do not roll your own crypto

- **Cost of breaking**: exploiting a mathematical property or a bug can break a scheme **much faster than** $2^{|K|}$ attempts, reducing its bit security.
- **The difficulty**: designing mathematically secure primitives, resistant to subtle attacks, is **incredibly hard**.
- **Conclusion**: **never design your own** stream cipher, block cipher, or hash function.
- **Best practice**: use **well-vetted, peer-reviewed, standard algorithms and their implementations** (AES, ChaCha20, SHA-3).

Remark 60.
This is the same philosophy as for security models in the MAC lecture ("use a well-known model rather than inventing your own"), and an application of **open design**: standard algorithms are public and have survived years of public cryptanalysis, which is precisely what gives confidence in them.

4.6 Public-key cryptography

4.6.1 Recap: the key distribution problem

Symmetric ciphers are fast, but require a **pre-shared secret key**.

Question: how can Alice and Bob agree on a secret key if **all their communication is observed by Eve**?

The magic of asymmetric crypto.

- **The paradox**: before the 1970s, it was considered **impossible** to communicate securely without a pre-shared secret.
- **The revelation**: **public-key cryptography** allows two parties who have **never met** to establish a secure channel over a public one.

4.6.2 Diffie–Hellman key exchange

Definition 62 (Diffie–Hellman (DH) key exchange)**.**
Public parameters, known by Alice, Bob *and Eve*: a large prime number p and a generator g.

Alice	**Bob**
1. Chooses a private secret a.	1. Chooses a private secret b.
2. Computes the public value $A = g^a \bmod p$.	2. Computes the public value $B = g^b \bmod p$.
3. Sends A to Bob.	3. Sends B to Alice.
4. Computes $K = B^a \bmod p$.	4. Computes $K = A^b \bmod p$.

The shared secret. Both obtain the same value:

$$\boxed{K = B^a = (g^b)^a = g^{ba} = g^{ab} = (g^a)^b = A^b \pmod p}$$

- $K = B^a \bmod p$ is computable by **Alice** (she has the secret a and received B);
- $K = A^b \bmod p$ is computable by **Bob** (he has the secret b and received A);
- **Eve** sees A, B, g and p, but **cannot compute** K: she has neither a nor b, and cannot find them because of the **Discrete Logarithm Problem**.

Definition 63 (Discrete Logarithm Problem)**.**
Given p, g and $A = g^a \bmod p$, find a. Computing $g^a \bmod p$ is easy (e.g. with **fast modular exponentiation**, square-and-multiply, in $O(\log a)$ multiplications), but there is **no known fast (polynomial) algorithm** to recover a from A and p (nor b from B).

[Toy DH, with tiny numbers] $p = 23$, $g = 5$. Alice picks $a = 6$, Bob picks $b = 15$.

- $A = 5^6 \bmod 23 = 8$ $\quad (5^2 = 25 \equiv 2,\ 5^4 \equiv 4,\ 5^6 \equiv 4 \cdot 2 = 8)$;
- $B = 5^{15} \bmod 23 = 19$;
- Alice: $K = B^a = 19^6 \bmod 23 = 2$; $\quad$ Bob: $K = A^b = 8^{15} \bmod 23 = 2$.

Eve sees $p = 23$, $g = 5$, $A = 8$, $B = 19$. With such small numbers she can brute force a, but with p of thousands of bits this is infeasible.

4.6.3 Trapdoor (one-way) functions

- DH is one of many examples of how to use public-key cryptography to **establish a shared secret** (a shared key) that is then used for **symmetric cryptography**.
- Such schemes boil down to mathematical functions that are **easy to compute in one direction** but **hard (high complexity) to compute in the other direction**.
- For DH, the underlying difficulty is the **Discrete Logarithm Problem**.

Remark 61.
Typical combination (*hybrid encryption*): use slow public-key crypto only to agree on a short key, then encrypt the bulk of the data with fast symmetric crypto (AES, ChaCha20) under that key. This is how HTTPS, VPNs and messaging apps work.

4.6.4 Beyond Diffie–Hellman

There are other ways to set up a shared secret (or even to directly communicate), all involving interesting mathematics:

- **RSA**: based on the hardness of the **factoring** problem;
- **Elliptic Curve Cryptography (ECC)**: the discrete logarithm problem on elliptic curves instead of on integers modulo p (smaller keys for the same security);
- **Post-Quantum Cryptography**: new primitives (e.g. **lattice** cryptography) designed to resist **quantum computers**, which could solve factoring and discrete log efficiently.

4.6.5 Man-in-the-Middle (MITM) attack

Vanilla DH is vulnerable to an active attack. DH only guarantees **key agreement**, **not authenticity**: Alice does not verify *who* she is agreeing with. DH is secure against a *passive* eavesdropper, but not against an *active* adversary who can intercept and replace messages.

1. **Eve intercepts** A from Alice and B from Bob (they never reach their destination).
2. **Eve impersonates** each party, using her own secret(s):
   - Eve sends E_B to Alice (pretending to be Bob). Alice computes a key K_{AE}, shared with Eve.
   - Eve sends E_A to Bob (pretending to be Alice). Bob computes a key K_{BE}, shared with Eve.
3. Eve now shares a key K_{AE} with Alice and a separate key K_{BE} with Bob. Each message from Alice is decrypted by Eve with K_{AE}, read (and possibly modified), re-encrypted with K_{BE} and relayed to Bob, and vice versa.

Result: Eve can **read, modify and relay all communication**, while Alice and Bob believe they have a private channel with each other.

4.6.6 The need for trust (authentication)

- DH **solves the key distribution problem**, but creates the **identity verification problem**: is B really Bob's?
- **Solution**: DH must be paired with a mechanism to **verify identity**, such as **digital signatures** (next lecture).
- **Setup**: parties still need to **trust a third party**, a **Certificate Authority** (CA), that vouches for the ownership of public keys.

Remark 62.
This is exactly the "integrity bootstraps confidentiality" argument of the MAC lecture (PKI): perfect encryption is useless if the adversary can substitute her own key for Bob's. Confidentiality needs the **integrity / authenticity of the public values**.

4.7 Summary

- Cryptography protects data **in transit** and **at rest**; it builds confidentiality, integrity, authentication, anonymity. Core problem: Alice talks to Bob over a channel observed by Eve.
- Encryption: $C = E_K(M)$, $M = D_K(C)$. **Correctness**: $D_K(E_K(M)) = M$ for all K, M. **Security**: hard to invert without K; ideally, the only attack is **brute force** over the key space. Only the key is secret, not the algorithm (open design).
- **Bits of security**: the best attack costs 2^N. A large key space is necessary but not sufficient: **Caesar** (25 keys, 4.6 bits) and **substitution** (26! keys, ≈ 88 bits nominal) are both broken by **frequency analysis**, because they preserve the statistics of the language.
- **Adversary models**: passive eavesdropper (ciphertext only) < **KPA** (known (M, C) pairs, realistic due to structured data) < **CPA** (encryption oracle; breaks substitution in one query). **Side channels** (timing, power) attack the implementation (DRM, smart cards).
- **One-Time Pad**: $c = m \oplus k$, $m = c \oplus k$, with k truly random, as long as m, used once. **Perfect secrecy**: $P(M = m \mid C = c) = P(M = m)$, secure even against unbounded adversaries.
- OTP limits: **key distribution** of message-length keys is impractical; **key reuse** gives $C_1 \oplus C_2 = M_1 \oplus M_2$ (space trick, dictionary attack); **no integrity**: bit flipping $C \oplus \Delta \to M \oplus \Delta$ (malleability).
- **Symmetric crypto**: same key for encryption and decryption; short, reused, secret keys. Block ciphers (AES) vs. **stream ciphers** (ChaCha20).
- **Stream cipher**: $S = \mathrm{KSG}(K, \mathrm{IV})$, $C = M \oplus S$. Security is **computational**: S indistinguishable from random without K. The **IV** (public, never repeated under the same key) avoids reusing the same stream. Low diffusion, malleable, fast, low error propagation. Finite state $\Rightarrow$ periodic.
- **LFSRs**: fast, period $2^L - 1$ and balanced if the polynomial is primitive, but **linear** (Berlekamp–Massey): only a building block. **A5/1** (GSM) broken; **Trivium**, **Salsa20/ChaCha20** not. **Never roll your own crypto**: use AES, ChaCha20, SHA-3.
- **Public-key crypto** solves key distribution. **Diffie–Hellman**: public p, g; $A = g^a$, $B = g^b$; $K = B^a = A^b = g^{ab} \bmod p$. Security from the **discrete logarithm problem** (easy one way, hard the other). Other: RSA (factoring), ECC, post-quantum (lattices).
- Vanilla DH gives key agreement but **no authenticity**: vulnerable to **Man-in-the-Middle**. It must be combined with **digital signatures** and trusted **Certificate Authorities**.